

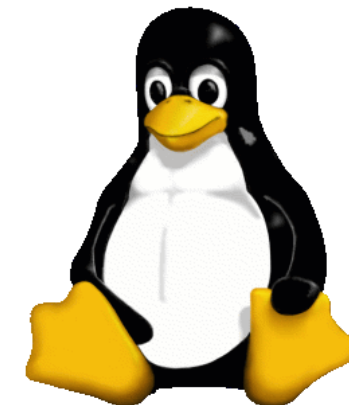
La levée de doute

- un processus essentiel de vérification et d'investigation approfondie

Il s'agit d'observer le système en fonctionnement pour diagnostiquer par exemple :

- la charge CPU/mémoire,
- les processus gourmands,
- les fichiers ouverts,
- les connexions réseau actives,
- les performances I/O.

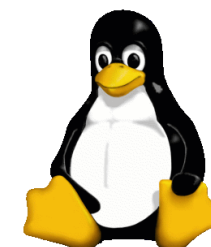
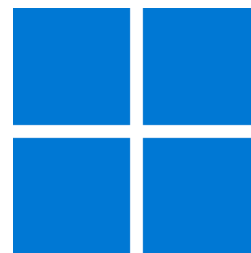
Analyser son environnement



TESTONS NOS
CONNAISSANCES

59

Pouvez-vous me citer des commandes qui permettent d'observer les services actifs à l'écoute du réseau ?





Commandes sous Windows (cmd)



Définition :

Netstat est un mélange des termes *network* (réseau en anglais) et *statistics* (statistiques).

st un programme piloté via une ligne de commandes. Il livre des statistiques de base sur toutes les activités de réseau et donne par exemple des indications sur le **port et l'adresse** sur lesquels une connexion (TCP, UDP) est établie, mais également des indications sur quels ports sont ouverts pour des demandes.

C'e



Commandes sous Windows (cmd)

OPTION]	Commande	Description de l'option
	netstat	Listage standard de toutes les connexions actives
-a	netstat -a	Liste aussi les ports ouverts en supplément
-e	netstat -e	Statistiques de l'interface (paquets de données émis et reçus)
-i	netstat -i	Charge l'aperçu du menu Netstat
-n	netstat -n	Affichage numérique des adresses et numéros de ports
-p protocole	netstat -p TCP	Indique les contacts pour le protocole indiqué (dans ce cas TCP, mais UDP, TCPv6 ou UDPv6 sont également possibles)
-q	Netstat-q	Liste toutes les connexions, tous les ports TCP en cours d'écoute et tous les ports TCP ouverts qui ne sont pas à l'écoute
-r	netstat -r	Affiche le tableau de routing
-s	Netstat-s	Récupère des statistiques sur les protocoles réseau importants tels que TCP, IP ou UDP

63



1. Commandes sous Windows (cmd)



1. Utiliser la commande netstat (basique mais efficace)

Ouvrir l'invite de commande (cmd) puis taper :

```
netstat -an
```

Cela affiche :

- ☐ Toutes les connexions réseau (-a)
- ☐ Sous forme numérique, sans tenter de résoudre les noms (-n)



64



1. Commandes sous Windows (cmd)

1. Utiliser la commande netstat (basique mais efficace)

netstat -an

- **Proto** : Protocole utilisé, ici TCP (Transmission Control Protocol).
- **Adresse locale** : Adresse IP + port sur lesquels la machine locale **écoute**. 0.0.0.0 signifie **toutes les interfaces réseau locales**.
- **Adresse distante** : Pour les connexions établies, cela afficherait l'adresse du client distant. Ici, 0.0.0.0:0 indique que la socket est en **mode écoute (LISTENING)**.
- **État** : État de la connexion. LISTENING signifie que le port est **ouvert et en attente de connexions entrantes**.

Connexions actives

Proto	Adresse locale	Adresse distante	État
TCP	0.0.0.0:22	0.0.0.0:0	LISTENING
TCP	0.0.0.0:135	0.0.0.0:0	LISTENING



65



1. Commandes sous Windows (cmd)



1. Utiliser la commande netstat (basique mais efficace)

👉 Pour filtrer les connexions **actives** seulement :

```
netstat -an | findstr ESTABLISHED
```

Protocole	Adresse locale	Adresse distante	État
TCP	192.168.1.32:51246	13.248.212.111:443	ESTABLISHED
TCP	192.168.1.32:51837	216.58.215.42:443	CLOSE_WAIT
TCP	192.168.1.32:52305	192.168.1.254:53	TIME_WAIT
TCP	192.168.1.32:52311	13.107.255.236:443	SYN_SENT
TCP	192.168.56.1:139	0.0.0.0:0	LISTENING



66



1. Commandes sous Windows (cmd)



1. Utiliser la commande netstat (basique mais efficace)



Interprétation des résultats :



1. ESTABLISHED



La connexion TCP est active et établie. Cela signifie que le **handshake à 3 étapes (SYN, SYN-ACK, ACK)** est terminé.



2. CLOSE_WAIT



La machine **locale** a **reçu une demande de fermeture** de connexion du serveur distant. Mais elle n'a **pas encore terminé** la fermeture de son côté (pas encore envoyé son propre FIN).



Généralement causé par une **application qui ne ferme pas proprement le socket**.



67



1. Commandes sous Windows (cmd)



1. Utiliser la commande netstat (basique mais efficace)



Interprétation des résultats :



3. TIME_WAIT

🕒 La connexion est **fermée des deux côtés**, mais TCP garde l'entrée pendant un court délai (typiquement $2 \times$ durée de vie d'un segment) pour :

- Empêcher les doublons de paquets anciens
- Nettoyer proprement la connexion

👉 Connexion **récemment fermée**, en attente d'expiration du timeout.



4. SYN_SENT



L'ordinateur **a envoyé un SYN** pour initier une connexion, mais **attend encore la réponse SYN-ACK** du serveur.



Cela signifie que **le handshake n'est pas encore terminé**.



68



1. Commandes sous Windows (cmd)



1. Utiliser la commande netstat (basique mais efficace)



Interprétation des résultats :



5. LISTENING



Le port est **ouvert** et prêt à accepter des connexions entrantes.



C'est un **serveur** ou un service local qui attend des connexions.



69



1. Commandes sous Windows (cmd)



1. Utiliser la commande netstat (basique mais efficace)



En résumé visuel

[LISTENING]	→ en attente de connexions entrantes
[SYN_SENT]	→ en train de négocier l'ouverture (main tendue)
[ESTABLISHED]	→ connexion active
[CLOSE_WAIT]	→ serveur a coupé, client n'a pas terminé
[TIME_WAIT]	→ connexion fermée, nettoyage en cours



70



1. Commandes sous Windows (cmd)



1. Utiliser la commande netstat (basique mais efficace)



Bonnes pratiques sécurité

- Trop de **CLOSE_WAIT** → regarde ton code/applications, elles ne ferment pas proprement.
- Trop de **SYN_SENT** → possible problème réseau, ou tentative de scan bloqué. Trop de
- **LISTENING** → inutile si les services ne sont pas utilisés (surface d'attaque).
- **TIME_WAIT** élevé = normal sur un serveur très actif, mais tu peux ajuster `tcp_fin_timeout` (Linux).

71



1. Commandes sous Windows (cmd)



2. Avec informations sur les processus (-b)

netstat -abn

Cela affiche les **exécutables** responsables des connexions (**besoin d'exécuter en administrateur**).

 Exemple : Observer **chrome.exe** si votre navigateur est connecté à un site.

```
TCP      192.168.1.10:54101      64.233.167.188:5228      ESTABLISHED
[chrome.exe]
TCP      192.168.1.10:54210      104.18.32.47:443         ESTABLISHED
[chrome.exe]
TCP      192.168.1.10:54391      192.168.1.26:443         ESTABLISHED
[chrome.exe]
TCP      192.168.1.10:54557      52.111.231.17:443        ESTABLISHED
```

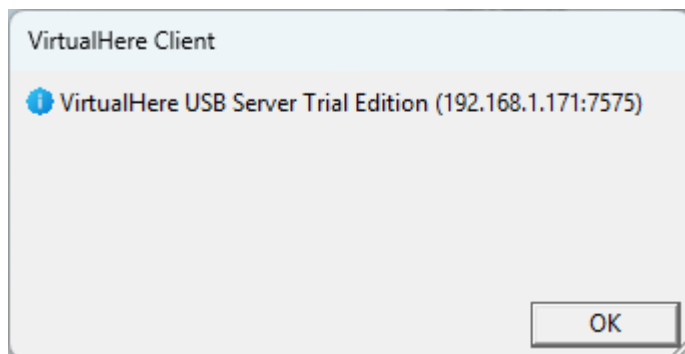
72



1. Commandes sous Windows (cmd)

📌 Exemple : Observer une **application** connectée en cours d'exécution.

```
TCP      192.168.1.10:54568      192.168.1.171:7575      ESTABLISHED  
[vhui64.exe]
```



```
TCP      192.168.1.10:64675      162.159.136.234:443      ESTABLISHED  
[Discord.exe]
```


besoin d'exécuter en **administrateur**

73



1. Commandes sous Windows (cmd)



2. Connexion avec une adresse IP connue (-ano)



Exemple :

```
netstat -ano | findstr 192.168.0.60
```

```
TCP      192.168.1.10:65126      192.168.0.60:1514      ESTABLISHED      11068
```

La **colonne de droite** donne le **PID** (ici 11068), pour trouver le **nom du processus** :

```
tasklist /FI "PID eq 11068"
```

Nom de l'image	PID	Nom de la sessio	Numéro de s	Utilisation
=====	=====	=====	=====	=====
wazuh-agent.exe	11068	Services	0	37 672 Ko

besoin d'exécuter en **administrateur**

74



1. Commandes sous Windows (cmd)



3. Statistiques détaillées liées aux protocoles IP

```
netstat -s -p IP
```

Élément	Signification
netstat	Outil en ligne de commande qui affiche les connexions réseau et statistiques
-s	Affiche les statistiques par protocole
-p IP	Filtre pour ne montrer que les statistiques du protocole IP

 très utile pour analyser les **anomalies réseau** ou les **comportements suspects**.

besoin d'exécuter en **administrateur**

75



1. Commandes sous Windows (cmd)

3. Statistiques détaillées liées aux protocoles IP

`netstat -s -p IP`

Statistiques IP

```
Paquets reçus = 265004
Paquets reçus en erreur = 4
Paquets reçus ignorés = 0
Paquets reçus délivrés = 264999
Paquets envoyés = 322121
Requêtes de réacheminement = 0
Paquets de fragmentation = 0
Paquets réassemblés = 0
```

🔍 À quoi ça sert concrètement ?

Pour un administrateur réseau ou un enseignant :

- ☐ Diagnostiquer une **saturation de réseau**
- ☐ Identifier une **anomalie de réception**
- ☐ Repérer un **flood**, une **attaque réseau**
(beaucoup d'erreurs ou de paquets ignorés)
- ☐ Comparer l'évolution des statistiques dans le temps (avant/après une opération réseau)

besoin d'exécuter en **administrateur**

76



1. Commandes sous Windows (cmd)

3. Statistiques détaillées liées aux protocoles IP

```
netstat -s -p IP
```

Ligne	Description
Paquets reçus	Nombre total de paquets IP reçus par la machine
Paquets reçus en erreur	Paquets mal formés, trop petits, corrompus
Paquets reçus ignorés	Paquets valides mais non utilisés (pas de port en écoute, par ex.)
Paquets envoyés	Nombre total de paquets IP envoyés
Requêtes de réacheminement	Si la machine agit comme routeur (souvent 0)
Paquets de fragmentation	Indique si le système fragmente encore les paquets IP
Paquets réassemblés	Nombre de fragments IP reconstruits en un paquet complet

besoin d'exécuter en **administrateur**

77



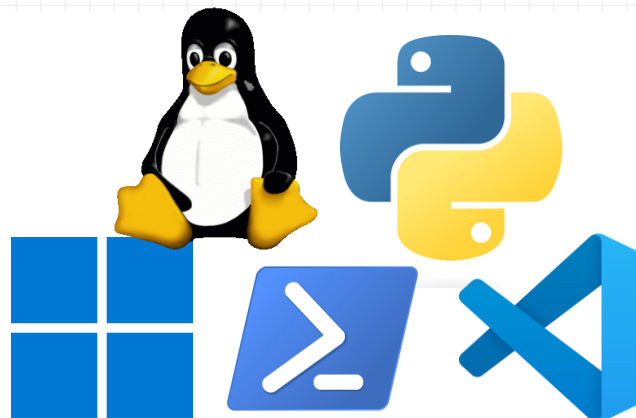
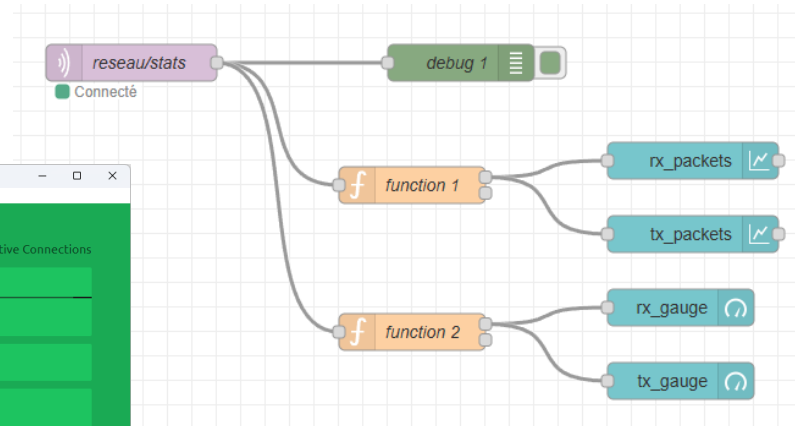
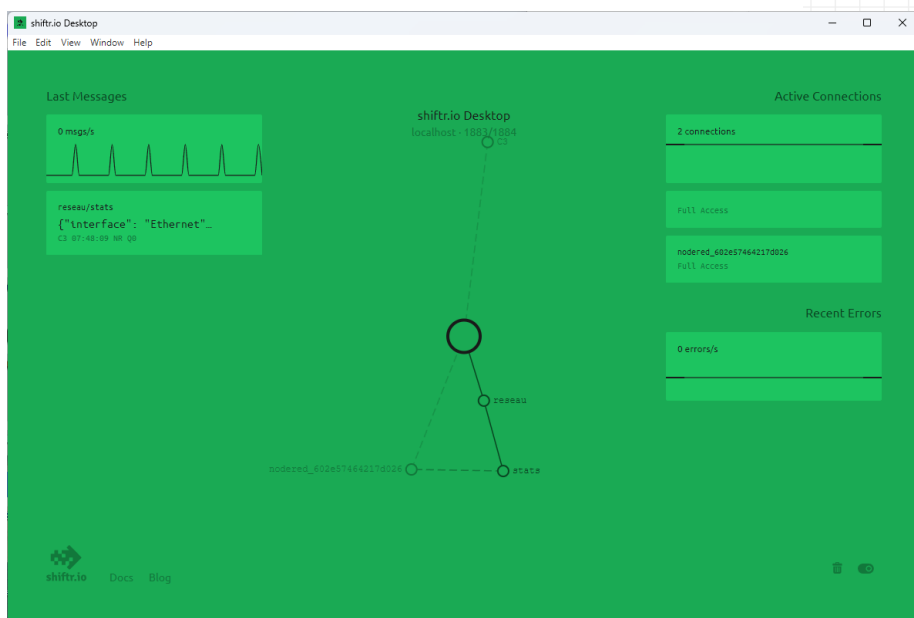
1. Commandes sous Windows (cmd)



très utile pour analyser les anomalies réseau ou les comportements suspects.

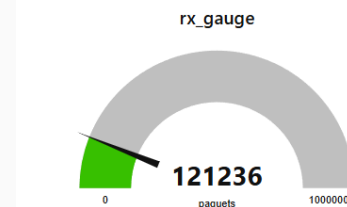


4. Travaux pratique

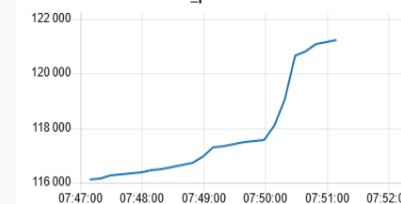
**netstat -s -p IP**

Nombre actuel de paquets reçus/émis

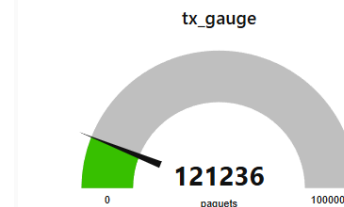
tx_paquets



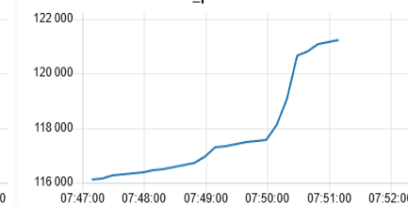
tx_packets



rx_paquets



rx_packets



PowerShell



79



2. Commandes sous Windows (PowerShell)



1. Afficher les connexions actives

```
Get-NetTCPConnection | Where-Object {$_.State -eq "Established"}
```

LocalAddress	LocalPort	RemoteAddress	RemotePort	State	AppliedSetting	OwningProcess
-----	-----	-----	-----	-----	-----	-----
fe80::baae:e696:f6b0:cad%20	54386	fe80::211:32ff:fef1:1edf%20	445	Established	Internet	4
192.168.1.10	65126	192.168.0.60	1514	Established	Internet	11068
127.0.0.1	60972	127.0.0.1	60971	Established	Internet	12124
127.0.0.1	60971	127.0.0.1	60972	Established	Internet	12124
127.0.0.1	60021	127.0.0.1	1844	Established	Internet	41828



2. Commandes sous Windows (PowerShell)

2. Afficher les connexions avec les noms des programmes associés

```
Get-NetTCPConnection | Select-Object -Property LocalAddress, LocalPort,  
RemoteAddress, RemotePort, State, OwningProcess |  
    ForEach-Object {  
        $_ | Add-Member -MemberType NoteProperty -Name "ProcessName" -Value  
(Get-Process -Id $_.OwningProcess).ProcessName -PassThru  
    }
```

```
LocalAddress : 192.168.1.10  
LocalPort    : 53359  
RemoteAddress : 142.251.116.94  
RemotePort   : 443  
State        : Established  
OwningProcess : 25496  
ProcessName  : chrome
```

```
LocalAddress : 192.168.1.10  
LocalPort    : 53323  
RemoteAddress : 142.251.116.94  
RemotePort   : 443  
State        : TimeWait  
OwningProcess : 0  
ProcessName  : Idle
```

81



2. Commandes sous Windows (PowerShell)

3. Afficher en ligne les connexions avec les noms des programmes associés

```
Get-NetTCPConnection | Select-Object -Property LocalAddress, LocalPort, RemoteAddress, RemotePort, State, OwningProcess |  
ForEach-Object {  
    try {  
        $procName = (Get-Process -Id $_.OwningProcess -ErrorAction Stop).ProcessName  
    } catch {  
        $procName = "N/A"  
    }  
    "$($_.LocalAddress):$($_.LocalPort) -> $($_.RemoteAddress):$($_.RemotePort) [$_.State] (PID: $_.OwningProcess), Proc: $procName)"  
}
```

```
192.168.1.10:54568 -> 192.168.1.171:7575 [Established] (PID: 26496, Proc: vhui64)  
192.168.1.10:54101 -> 64.233.167.188:5228 [Established] (PID: 25496, Proc: chrome)
```



2. Commandes sous Windows (PowerShell)



4. Faire un script ciblant une adresse IP suspecte (.\recherche_ip.ps1)

```
$ip = "192.168.xx.xx"
Get-NetTCPConnection | Where-Object { $_.RemoteAddress -eq $ip } |
  ForEach-Object {
    $proc = Get-Process -Id $_.OwningProcess -ErrorAction SilentlyContinue
    [PSCustomObject]@{
      LocalAddress    = $_.LocalAddress
      LocalPort       = $_.LocalPort
      RemoteAddress   = $_.RemoteAddress
      RemotePort      = $_.RemotePort
      State           = $_.State
      ProcessName     = if ($proc) { $proc.ProcessName } else { "N/A" }
      PID             = $_.OwningProcess
    }
  } | Format-Table -AutoSize
```

83



2. Commandes sous Windows (PowerShell)

4. Faire un script ciblant une adresse IP (.\\recherche_ip.ps1)

Affichage

LocalAddress	LocalPort	RemoteAddress	RemotePort	State	ProcessName	PID
-----	-----	-----	-----	-----	-----	---
192.168.1.10	65126	192.168.0.60	1514	Established	wazuh-agent	11068

84



2. Commandes sous Windows (PowerShell)

5. Lever la restriction d'exécution temporairement

```
Powershell -ExecutionPolicy UnRestricted -command ".\recherche_ip.ps1"
```

6. Faire un script ciblant une adresse IP (.\recherche_ip.ps1)

Affichage

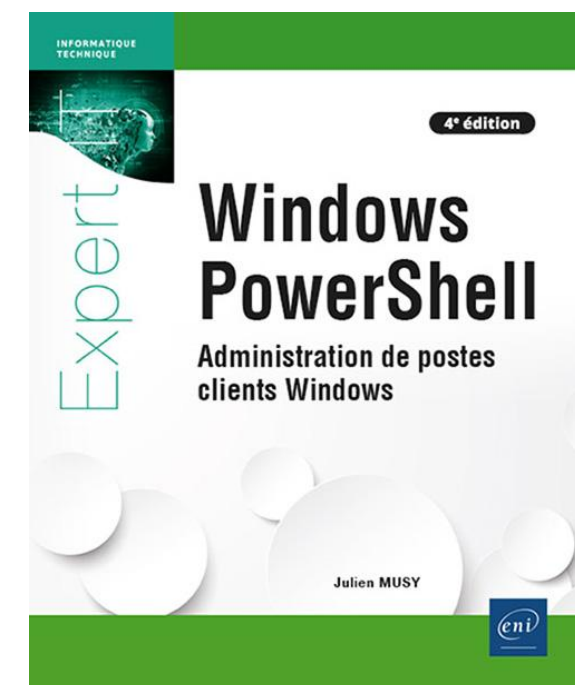
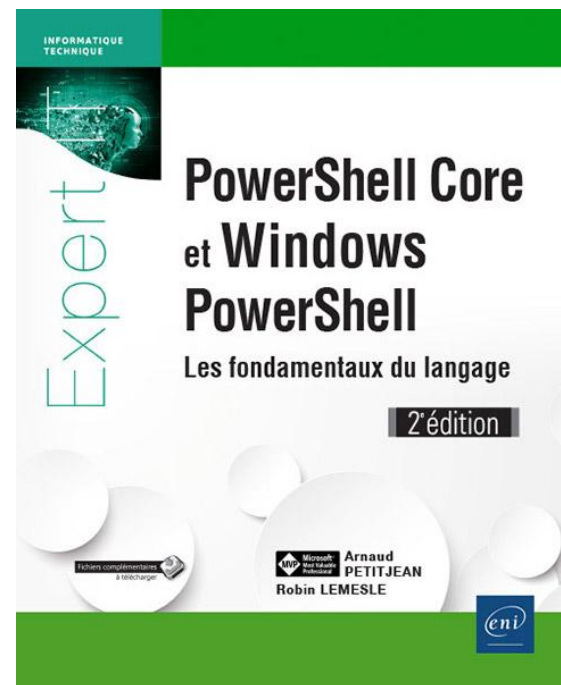
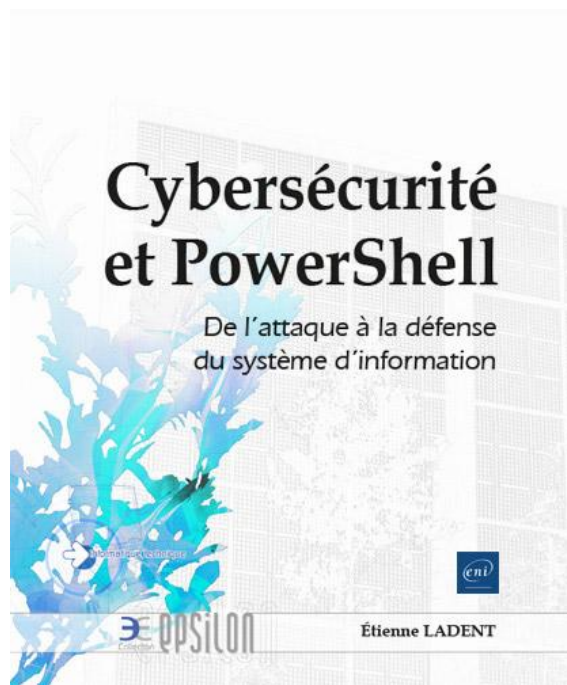
LocalAddress	LocalPort	RemoteAddress	RemotePort	State	ProcessName	PID
-----	-----	-----	-----	----	-----	---
192.168.1.10	65126	192.168.0.60	1514	Established	wazuh-agent	11068



2. Commandes sous Windows (Powershell)

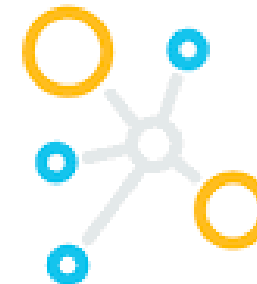
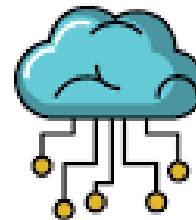


3. Un peu de lecture

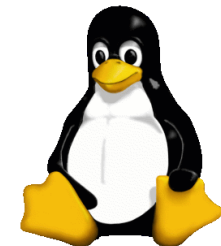


SS

NETSTAT



SS



/07/2025

86



Commande sous Linux « ss (Socket Statistics) »

Définition (plus moderne, remplace netstat) :

- ☐ La commande **ss** est utilisée sous Linux pour afficher des informations détaillées sur les sockets réseau ainsi que les connexions TCP et UDP.
- ☐ La commande **ss** est fourni par le paquet iproute, installé sur toutes les distributions Linux.
- ☐ La commande **ss** obtient ses informations directement à partir de l'espace noyau

88



Commande sous Linux « ss (Socket Statistics) »



Exemple de la commande

```
sudo ss -tunp
```

Lister les ports ouverts en écoute + PID

Option	Signification
-t	TCP connections
-u	UDP connections
-n	Pas de résolution DNS
-p	Affiche le PID et nom du processus associé

89



Commande sous Linux « ss (Socket Statistics) »



4. Lister les ports ouverts en écoute + PID

Netid	State	Recv-Q	Send-Q	Local Address : Port	Peer Address : Port	Process
udp	UNCONN	0	0	0.0.0.0:5353	0.0.0.0:*	users:(("avahi-daemon",pid=458,fd=12))
udp	UNCONN	0	0	*:5353	*:*	users:(("avahi-daemon",pid=458,fd=13))
tcp	LISTEN	0	128	127.0.0.1:6010	0.0.0.0:*	users:(("sshd",pid=2076,fd=9))
tcp	LISTEN	0	128	0.0.0.0:22	0.0.0.0:*	users:(("sshd",pid=597,fd=3))
tcp	LISTEN	0	4096	0.0.0.0:8082	0.0.0.0:*	users:(("docker-proxy",pid=1024,fd=4))
tcp	LISTEN	0	4096	0.0.0.0:8080	0.0.0.0:*	users:(("docker-proxy",pid=999,fd=4))
tcp	LISTEN	0	4096	:::8082	:::*	users:(("docker-proxy",pid=1031,fd=4))
tcp	LISTEN	0	4096	:::8080	:::*	users:(("docker-proxy",pid=1006,fd=4))



Interprétation des résultats

Colonne	Signification
Netid	Type de socket : • tcp / tcp6 (Transmission Control Protocol) • udp / udp6 (User Datagram Protocol) • unix , raw ...
State	État de la connexion : • LISTEN : socket en écoute (serveur) • ESTAB (ESTABLISHED) : connexion active • CLOSE-WAIT , TIME-WAIT ...
Recv-Q	Longueur de la file d'attente de réception (en octets) : accumulé lorsque l'application n'a pas lu les données entrantes.
Send-Q	Longueur de la file d'attente d'envoi (en octets) : données prêtes à être envoyées, en attente de l'acquittement du pair.
Local Address:Port	Adresse locale et port associé à la socket : c'est l' extrémité locale du socket, à savoir l'adresse IP et le port sur votre machine. • 0.0.0.0:68 signifie "toutes interfaces, port 68" • 127.0.0.1:631 (loopback uniquement)
Peer Address:Port	Adresse distante et port : 'est l' extrémité distante du socket — l'IP et le port de la machine distante avec laquelle on communique. • 0.0.0.0:* pour les sockets en écoute • 192.168.1.5:54321 pour une connexion établie,
Process	(option -p ou -n combiné) Montre le nom du programme, son PID et le descripteur de socket (fd). Ex. ("sshd", pid=1234, fd=4)



À quoi servent ces informations ?

❑ Troubleshooting :

- Un **Recv-Q** élevé peut indiquer que l'application ne lit pas assez vite les données reçues.
- Un **Send-Q** grand suggère un souci de bande passante ou un pair lent.

❑ Sécurité & audit :

- Repérer rapidement les services en écoute (**LISTEN**) et vérifier qu'ils sont bien légitimes.
- Vérifier qu'aucune connexion non autorisée n'est établie (**ESTAB**).

❑ Performance réseau :

- Surveiller le nombre de connexions **TIME-WAIT**, souvent signe d'un trafic HTTP important.
- Diagnostiquer les fuites de sockets (nombre croissant de **CLOSE-WAIT**).



Commande sous Linux « ss (Socket Statistics) »

✓ Informations devant attirer votre attention en priorité

Netid	State	Recv-Q	Send-Q	Local Address : Port	Peer Address : Port	Process
udp	UNCONN	0	0	0.0.0.0:5353	0.0.0.0:*	users:(("avahi-daemon",pid=458,fd=12))
udp	UNCONN	0	0	*:5353	*:*	users:(("avahi-daemon",pid=458,fd=13))
tcp	LISTEN	0	128	127.0.0.1:6010	0.0.0.0:*	users:(("sshd",pid=2076,fd=9))
tcp	LISTEN	0	128	0.0.0.0:22	0.0.0.0:*	users:(("sshd",pid=597,fd=3))
tcp	LISTEN	0	4096	0.0.0.0:8082	0.0.0.0:*	users:(("docker-proxy",pid=1024,fd=4))
tcp	LISTEN	0	4096	0.0.0.0:8080	0.0.0.0:*	users:(("docker-proxy",pid=999,fd=4))
tcp	LISTEN	0	4096	:::8082	:::*	users:(("docker-proxy",pid=1031,fd=4))
tcp	LISTEN	0	4096	:::8080	:::*	users:(("docker-proxy",pid=1006,fd=4))

93



Commande sous Linux « ss (Socket Statistics) »



Exemple de la commande

```
sudo ss -s
```



Vos
constatations

```
Total: 157
TCP: 4 (estab 1, closed 0, orphaned 0, timewait 0)

Transport Total      IP      IPv6
RAW        1         0        1
UDP        6         3        3
TCP        4         3        1
INET       11        6        5
FRAG       0         0        0
```

Résumé global, elle fournit un condensé du nombre de sockets par type et état

94



Commande sous Linux « ss (Socket Statistics) »



Exemple de la commande

```
sudo ss -tun
```



Vos
constatations

Netid	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port
udp	ESTAB	0	0	192.168.50.100:68	192.168.50.1:67
tcp	ESTAB	0	0	192.168.50.100:22	192.168.50.144:50148

Elle ne résout pas les noms, elle affiche les adresses et ports numériques (commande plus rapide).

95



Commande sous Linux « ss (Socket Statistics) »



Exemple de la commande

```
ss -tuln ' ( sport = :80 or sport = :443 ) '
```



Vos
constatations

Netid	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port
tcp	LISTEN	0	511	0.0.0.0:80	0.0.0.0:*

Filtrer par port ou état, elle ne retourne que les services écoutant sur HTTP/HTTPS.



N'oubliez pas de mettre des espaces dans les parenthèses

96



Commande sous Linux « ss (Socket Statistics) »



Exemple de la commande

```
ss -tuln ' ( sport = :22 ) '
```



Filtrer les
activités SSH

Netid	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port
tcp	LISTEN	0	128	0.0.0.0:22	0.0.0.0:*
tcp	LISTEN	0	128	:::22	:::*

Filtrer par port ou état, elle ne retourne que les services écoutant le port 22 (SSH)



N'oubliez pas de mettre des espaces

97



Commande sous Linux « ss (Socket Statistics) »



Observer une potentielle attaques en brute force

Identifiant : etu
Password : bonnet31

```
ssh etu@192.168.50.100
```

```
Lancement de 300 tentatives de connexion SSH sur 127.0.0.1 en tant que 'etu'...  
(Appuyez sur Ctrl+C pour arrêter)  
→ 50 tentatives effectuées...  
→ 100 tentatives effectuées...
```



```
watch -n 2 'ss -tn state time-wait | wc -l'
```

```
Every 2.0s: ss -tn state time-wait | wc -l  
1
```



```
Every 2.0s: ss -tn state time-wait | wc -l  
62
```

98



Commande sous Linux « ss (Socket Statistics) »

✓ L'enseignant lance l'attaque en brute force

```
sudo apt install sshpass  
chmod +x simulate_bruteforce.sh  
  
./simulate_bruteforce.sh 127.0.0.1 etu 300
```



```
Lancement de 300 tentatives de connexion SSH sur 127.0.0.1 en tant que 'etu'...  
(Appuyez sur Ctrl+C pour arrêter)  
→ 50 tentatives effectuées...  
→ 100 tentatives effectuées...
```

Isof



99

100



Un outil polyvalent sous linux

La commande **lsof** (pour **L**ist **O**pen **F**iles) est un outil très puissant sous Unix/Linux qui permet de :

- ☐ **Lister tous les fichiers** ouverts par les processus en cours.
- ☐ **Identifier** l'usage des ports réseau (sockets TCP/UDP).
- ☐ **Déboguer** des problèmes de fichiers bloqués ou de ressources inaccessibles.



Un outil polyvalent sous linux

Colonne	Signification
COMMAND	Nom de la commande/processus
PID	Numéro de processus
USER	Propriétaire du processus
FD	File Descriptor (ex. 1u pour stdout en lecture/écriture)
TYPE	Type de fichier (REG régulier, DIR répertoire, IPv4...)
NODE	Numéro d'inœud (inode) pour les fichiers
NAME	Chemin ou socket (ex. /var/log/syslog, TCP *:80 (LISTEN))

102



Commande sous Linux « ss (Socket Statistics) »



Exemple de la commande

```
sudo lsof
```

Lister tous les fichiers ouverts

COMMAND	PID	TID	TASKCMD	USER	FD	TYPE	DEVICE	SIZE/OFF	NODE	NAME
systemd	1			root	cwd	DIR	179,2	4096	2	/
systemd	1			root	rtd	DIR	179,2	4096	2	/
systemd	1			root	txt	REG	179,2	133464	5022	/usr/lib/systemd/systemd
systemd	1			root	mem	REG	179,2	198640	5619	/usr/lib/aarch64-linux-gnu/libgpg-error.so.0.33.1
systemd	1			root	mem	REG	179,2	592440	5740	/usr/lib/aarch64-linux-gnu/libpcr2-8.so.0.11.2
systemd	1			root	mem	REG	179,2	67504	5548	/usr/lib/aarch64-linux-gnu/libcap-ng.so.0.0.0
systemd	1			root	mem	REG	179,2	591960	1612	/usr/lib/aarch64-linux-gnu/libm.so.6
systemd	1			root	mem	REG	179,2	198584	1926	/usr/lib/aarch64-linux-gnu/liblzma.so.5.4.1
systemd	1			root	mem	REG	179,2	657352	5829	/usr/lib/aarch64-linux-gnu/libzstd.so.1.5.4
systemd	1			root	mem	REG	179,2	4597928	5555	/usr/lib/aarch64-linux-gnu/libcrypto.so.3

Usage : vérification générale, mais produit beaucoup de lignes.

103



Commande sous Linux « ss (Socket Statistics) »



Exemple de la commande

```
ps -aux
```

```
sudo lsof -p 1234
```

Filtrer par processus

COMMAND	PID	TID	TASKCMD	USER	FD	TYPE	DEVICE	SIZE/OFF	NODE	NAME
systemd	1			root	cwd	DIR	179,2	4096	2	/
systemd	1			root	rtd	DIR	179,2	4096	2	/
systemd	1			root	txt	REG	179,2	133464	5022	/usr/lib/systemd/systemd
systemd	1			root	mem	REG	179,2	198640	5619	/usr/lib/aarch64-linux-gnu/libgpg-error.so.0.33.1
systemd	1			root	mem	REG	179,2	592440	5740	/usr/lib/aarch64-linux-gnu/libpcre2-8.so.0.11.2
systemd	1			root	mem	REG	179,2	67504	5548	/usr/lib/aarch64-linux-gnu/libcap-ng.so.0.0.0
systemd	1			root	mem	REG	179,2	591960	1612	/usr/lib/aarch64-linux-gnu/libm.so.6
systemd	1			root	mem	REG	179,2	198584	1926	/usr/lib/aarch64-linux-gnu/liblzma.so.5.4.1
systemd	1			root	mem	REG	179,2	657352	5829	/usr/lib/aarch64-linux-gnu/libzstd.so.1.5.4
systemd	1			root	mem	REG	179,2	4597928	5555	/usr/lib/aarch64-linux-gnu/libcrypto.so.3

Objectif : voir tous les fichiers (logs, connexions réseau...) que le processus **PID 1234** a ouverts.

104



Commande sous Linux « ss (Socket Statistics) »



Exemple de la commande

```
ps -aux
```

```
sudo lsof -c sshd
```

Filtrer par nom de commande

```
fabrice@serveur:~$ sudo lsof -c sshd
COMMAND PID  USER  FD  TYPE             DEVICE SIZE/OFF  NODE NAME
sshd    597   root   cwd  DIR              179,2    4096     2 /
sshd    597   root   rtd  DIR              179,2    4096     2 /
sshd    597   root   txt  REG             179,2  1314416 18258 /usr/sbin/sshd
sshd    597   root   mem  REG             179,2   198640 5619 /usr/lib/aarch64-linux-gnu/libgpg-error.so.0.33.1
sshd    597   root   mem  REG             179,2   198960 5797 /usr/lib/aarch64-linux-gnu/libtirpc.so.3.0.0
sshd    597   root   mem  REG             179,2    68232 1622 /usr/lib/aarch64-linux-gnu/libresolv.so.2
sshd    597   root   mem  REG             179,2    67432 5649 /usr/lib/aarch64-linux-gnu/libkeyutils.so.1.10
sshd    597   root   mem  REG             179,2    68576 5654 /usr/lib/aarch64-linux-gnu/libkrb5support.so.0.1
sshd    597   root   mem  REG             179,2   199352 5648 /usr/lib/aarch64-linux-gnu/libk5crypto.so.3.1
sshd    597   root   mem  REG             179,2   592440 5740 /usr/lib/aarch64-linux-gnu/libpcrc2-8.so.0.11.2
sshd    597   root   mem  REG             179,2   199056 5672 /usr/lib/aarch64-linux-gnu/liblz4.so.1.9.4
```

Objectif : lister uniquement les fichiers ouverts par les processus dont le nom commence par "sshd".2.4. Trouver qui utilise un fichier ou un dossier.



TCPDUMP

TCPDUMP

105

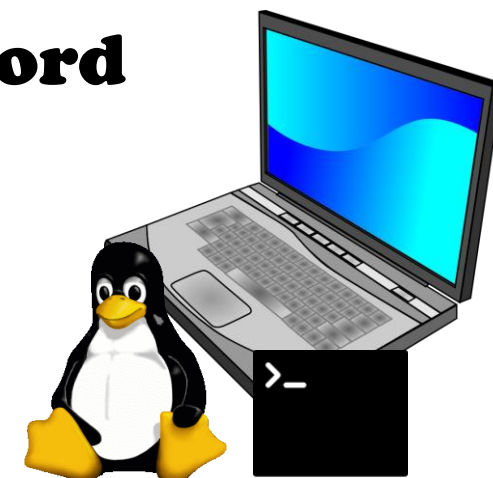
106



Créer un dossier de travail & journal de bord

 Structure proposée :

```
mkdir -p ~/analyse_reseau/captures  
touch ~/analyse_reseau/journal.md  
  
sudo apt install tcpdump
```



```
fabrice@serveur:~ $ tcpdump --version  
tcpdump version 4.99.3  
libpcap version 1.10.3 (with TPACKET_V3)  
OpenSSL 3.0.15 3 Sep 2024
```

107

Dossier de travail & journal de bord



Exemple de contenu du journal :

```
# Journal d'analyse - Groupe 2
## Interface : eth0
## Date : 16/04/2025

### 10h32 - Début de capture
- Aucune activité suspecte
- Ping observé depuis IP 192.168.1.50

### 10h48 - Scan de port
- Activité suspecte en TCP SYN
- Port 22, 80, 443 touchés
- Hypothèse : utilisation de nmap
```

```
### 11h02 - Tentative brute force SSH
- Logs montrent 8 connexions refusées
- Adresse IP attaquante : 192.168.1.200
```



Consigne étudiante : Notez le nom de l'interface utilisée pour la capture.

108

Lancement de la capture



Méthode 1 — filtrer sur l'interface eth0

```
sudo tcpdump -i eth0 -w ~/analyse_reseau/captures/capture1.pcap
```

- ❑ **-i eth0** : interface réseau
- ❑ **-w** : écrire vers un fichier .pcap lisible avec Wireshark



Consigne étudiante : Notez le nom de l'interface utilisée pour la capture.

109

Lancement de la capture

Méthode 2 – filtrer sur TCP sur le port 80 (HTTP)

```
sudo tcpdump -i eth0 -nn tcp port 80 -w ~/analyse_reseau/captures/capture2.pcap
```

- ☐ **-i eth0** : interface réseau
- ☐ **-w** : écrire vers un fichier .pcap lisible avec Wireshark
- ☐ **tcp port 80** : TCP sur le port 80
- ☐ **n** : Désactive la résolution DNS des adresses IP
- ☐ **n** : Désactive aussi la résolution des numéros de port en noms de services

110

Lancement de la capture

🧠 Méthode 3 – Afficher que les réponses HTTP « 200 OK » sur le port 80

```
sudo tcpdump -i eth0 -nn -s0 -A \  
  'tcp port 80 and (((ip[2:2] - ((ip[0]&0x0f)<<2) -  
  ((tcp[12]&0xf0)>>2)) > 0))' \  
  | grep --line-buffered -E '^.*HTTP/1\..1 200'
```

```
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode  
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes  
01:47:18.739771 IP 192.168.50.101.80 > 192.168.50.100.39174: Flags [P.], seq 1:16, ack 531, win 5229, length 15: HTTP: HTTP/1.1 200 OK [|http]  
E..7.w..@..0..2e..2d.P....=..s..P..m..\..HTTP/1.1 200 OK  
01:47:18.753243 IP 192.168.50.100.80 > 192.168.50.144.52032: Flags [P.], seq 1:797, ack 476, win 501, length 796: HTTP: HTTP/1.1 200 OK  
E..DI+@..@..D..2d..2..P.@.9..D.&.P....{..HTTP/1.1 200 OK  
01:47:18.941901 IP 192.168.50.102.80 > 192.168.50.100.44204: Flags [P.], seq 1:16, ack 448, win 5312, length 15: HTTP: HTTP/1.1 200 OK [|http]  
E..7.N..@..X..2f..2d.P...B"...E.P.....HTTP/1.1 200 OK  
01:47:18.959271 IP 192.168.50.100.80 > 192.168.50.144.52032: Flags [P.], seq 797:1594, ack 869, win 501, length 797: HTTP: HTTP/1.1 200 OK  
E..EI-@..@..A..2d..2..P.@.9..D.(.P....|..HTTP/1.1 200 OK  
01:47:19.136387 IP 192.168.50.101.80 > 192.168.50.100.39176: Flags [P.], seq 1:16, ack 531, win 5229, length 15: HTTP: HTTP/1.1 200 OK [|http]  
E..7.}..@..*..2e..2d.P....6...A.P..mJ7..HTTP/1.1 200 OK  
01:47:19.153636 IP 192.168.50.100.80 > 192.168.50.144.52032: Flags [P.], seq 1594:2389, ack 1345, win 501, length 795: HTTP: HTTP/1.1 200 OK
```

111

Lire une capture

Méthode 3 – Lire un fichier pcap

```
tcpdump -r analyse_reseau/captures/capture2.pcap -nn
```

- ☐ **-r** : lire vers un fichier .pcap
- ☐ **-n** : Désactive la résolution DNS des adresses IP
- ☐ **-n** : Désactive aussi la résolution des numéros de port en noms de services

112

Lire une capture

 Méthode 3 – Lire et filtrer uniquement les réponses HTTP 200

```
tcpdump -r analyse_reseau/captures/capture1.pcap -nn -A | grep --line-buffered  
-E -B2 'HTTP/1\..1 200'
```

```
reading from file analyse_reseau/captures/capture1.pcap, link-type EN10MB (Ethernet), snapshot length 262144  
  
01:19:27.563164 IP 192.168.50.101.80 > 192.168.50.100.38556: Flags [P.], seq 1:16, ack 506, win 5255, length 15: HTTP: HTTP/1.1 200 OK [|http]  
E..7.7..@..p..2e..2d.P..*..LW.pvP...c...HTTP/1.1 200 OK  
--  
01:19:27.580839 IP 192.168.50.100.38556 > 192.168.50.101.80: Flags [F.], seq 506, ack 1274, win 62967, length 0  
E..(D.@.@.....2d..2e...PW.pv*..EP....4..  
01:19:27.581159 IP 192.168.50.100.80 > 192.168.50.144.61580: Flags [P.], seq 1:796, ack 451, win 501, length 795: HTTP: HTTP/1.1 200 OK  
E..C..@.@.....2d..2..P...._...K.P....z..HTTP/1.1 200 OK  
--
```

113 Statistiques et graphiques

❑ Statistics → Protocol Hierarchy

- Vue arborescente du pourcentage de chaque protocole.

❑ Statistics → Conversations

- Liste des échanges entre deux IP, temps, quantité de données.

❑ Statistics → I/O Graphs

- Courbe du nombre de paquets ou d'octets en fonction du temps.
- Permet de visualiser les pics de trafic.

114

Récupération des identifiants dans le flux de connexion

Console ETUDIANTS

```
lftp ciel@192.168.50.1
```



Raspios
192.168.50.100

Console ENSEIGNANTS

```
sudo tcpdump -i eth0 -A -n port 21 | grep -E "USER|PASS"
```

```
sudo tcpdump -i eth0 -A -n port 21 -w capture_ftp.pcap
```

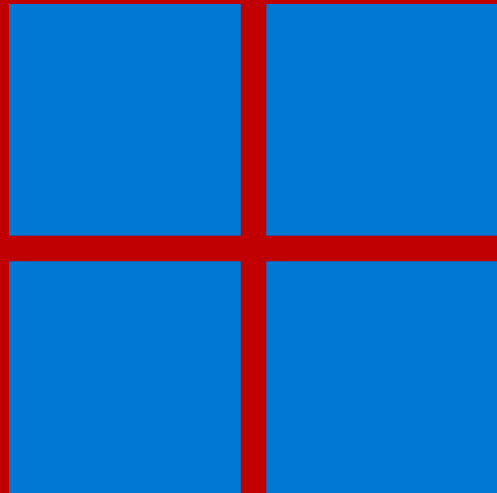
```
tcpdump -r capture_ftp.pcap -A | grep -E "USER|PASS"
```

115

Récupération des identifiants dans le flux de connexion

L'enseignant montre le résultat de la capture de flux

```
03:45:02.167738 IP 192.168.50.100.60990 > 192.168.50.1.21: Flags [P.],  
seq 17:28, ack 87, win 502, options [nop,nop,TS val 2272952690 ecr  
3044925], length 11: FTP: USER ciel  
.z.r..v=USER ciel  
03:45:02.168106 IP 192.168.50.100.60990 > 192.168.50.1.21: Flags [P.],  
seq 28:43, ack 125, win 502, options [nop,nop,TS val 2272952690 ecr  
3044925], length 15: FTP: PASS bonnet31  
.z.r..v=PASS bonnet31
```

TCPView



116

117



TCPView (Sysinternals – graphique)



Installation :

<https://docs.microsoft.com/en-us/sysinternals/downloads/tcpview>

Nom	Modifié le	Type	Taille
▼ Aujourd'hui			
 Eula.txt	23/04/2025 12:23	Document texte	8 Ko
 tcpvcon.exe	23/04/2025 12:23	Application	198 Ko
 tcpvcon64.exe	23/04/2025 12:23	Application	245 Ko
 tcpvcon64a.exe	23/04/2025 12:23	Application	232 Ko
 tcpview.chm	23/04/2025 12:23	Fichier HTML co...	16 Ko
 tcpview64a.exe	23/04/2025 12:23	Application	1 020 Ko
 tcpview.exe	23/04/2025 12:23	Application	923 Ko
 tcpview64.exe	23/04/2025 12:23	Application	1 062 Ko



118



TCPView (Sysinternals – graphique)

📁 Trier par processus (colonne Remote Address)



Process Name	Process ID	Protocol	State	Local Address	Local Port	Remote Address	Remote Port	Create Time	Module Name	Sent Packets	Recv Packets	Sent Bytes	Recv Bytes
GoogleDriveFS.exe	20920	TCP	Close Wait	192.168.1.10	56685	216.239.38.223	443	23/04/2025 12:35:15	GoogleDriveFS.exe				
AvastSvc.exe	8480	TCP	Established	192.168.1.10	52872	193.70.18.144	993	23/04/2025 10:05:27	avast! Antivirus	15	18	627	1338
AvastSvc.exe	8480	TCP	Established	192.168.1.10	52830	193.70.18.144	993	23/04/2025 10:04:58	avast! Antivirus	15	18	582	1296
AvastSvc.exe	8480	TCP	Established	192.168.1.10	52828	193.70.18.144	993	23/04/2025 10:04:58	avast! Antivirus	12	15	429	945
AvastSvc.exe	8480	TCP	Established	192.168.1.10	52824	193.70.18.144	993	23/04/2025 10:04:58	avast! Antivirus	15	18	591	1341
nextcloud.exe	24940	TCP	Established	192.168.1.10	57076	192.168.27.70	443	23/04/2025 12:42:51	nextcloud.exe				
chrome.exe	25496	TCP	Syn Sent	192.168.1.10	57057	192.168.1.214	443	23/04/2025 12:42:38	chrome.exe				
chrome.exe	25496	TCP	Syn Sent	192.168.1.10	57055	192.168.1.214	443	23/04/2025 12:42:37	chrome.exe				
vhui64.exe	26496	TCP	Established	192.168.1.10	54568	192.168.1.171	7575	23/04/2025 03:06:16	vhui64.exe	88	88	1880	1880
UrBackupClientBacke...	10600	TCP	Established	192.168.1.10	35623	192.168.1.31	54798	23/04/2025 02:44:36	UrBackupClientBackend	2	2	16	16
wazuh-agent.exe	11068	TCP	Established	192.168.1.10	56097	192.168.0.60	1514	23/04/2025 12:25:46	WazuhSvc	316	8	107384	712
WhatsApp.exe	16364	TCP	Established	192.168.1.10	57058	185.60.219.60	443	23/04/2025 12:42:38	WhatsApp.exe	6	10	1164	3256
WhatsApp.exe	16364	TCP	Ack	192.168.1.10	56326	185.60.219.60	443	23/04/2025 12:28:53	WhatsApp.exe				
GoogleDriveFS.exe	20920	TCP	Established	192.168.1.10	55619	172.217.20.202	443	23/04/2025 12:16:09	GoogleDriveFS.exe		3		268

Endpoints: 203 Established: 75 Listening: 49 Time Wait: 9 Close Wait: 6 Update: 2 sec States: (All)

Address	Local Port	Remote Address	Remote Port
8.1.10	56685	216.239.38.223	443
8.1.10	52872	193.70.18.144	993
8.1.10	52830	193.70.18.144	993
8.1.10	52828	193.70.18.144	993

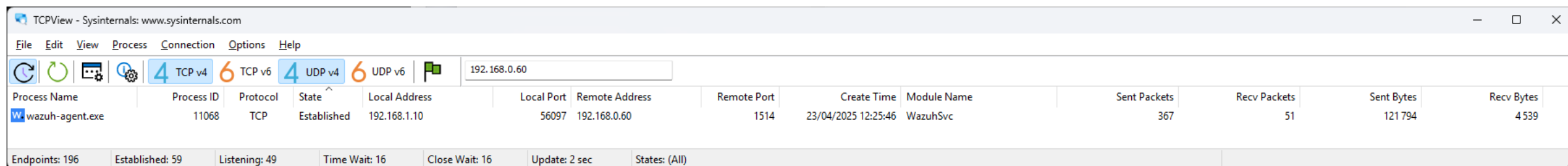
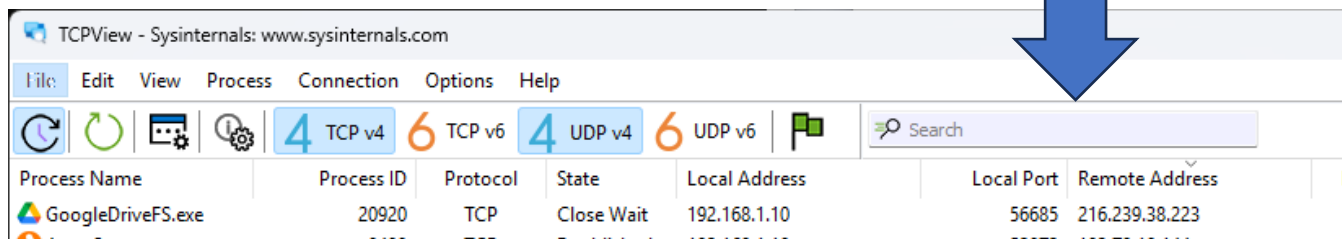
119



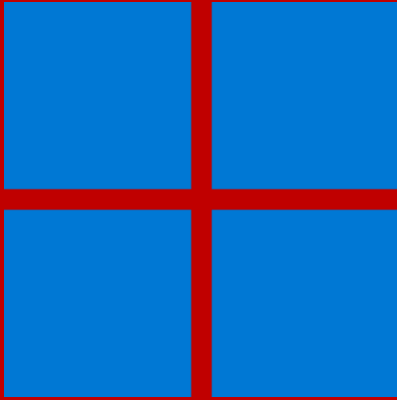
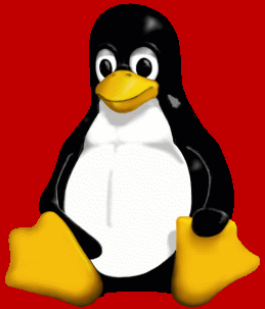
TCPView (Sysinternals – graphique)



Rechercher une adresse IP suspecte



WIRESHARK



120

121

Lancement de la capture

Méthode 1 – Capture avec Wireshark (GUI)

1. Ouvrez **Wireshark**
2. Cliquez sur l'interface réseau (ex: **eth0**)
3. Lancez la capture
4. Filtrez par :
 - **ip.addr** == 192.168.1.X (IP de la victime ou de Kali)
 - **tcp.port** == 22 pour SSH
 - **http** pour le trafic web
5. Sauvegardez la capture régulièrement



122

Lancement de la capture

🔧 Filtrage de trafic utile

- 1. Ouvrez **Wireshark**
- 2. Ouvrir la capture **capture1.pcap**



Besoin	Filtre tcpdump	Filtre Wireshark
Trafic HTTP	tcp port 80	http
Scan de port	tcp[tcpflags] & tcp-syn != 0	tcp.flags.syn == 1
SSH bruteforce	tcp port 22	tcp.port == 22
IP spécifique	host 192.168.1.200	ip.addr == 192.168.1.200
ICMP (ping)	ICMP (ping)	ICMP (ping)

123

**Résumé pédagogique**

Outil	Vue	Infos processus	Interface graphique	Pour qui ?
netstat	Oui	Oui (avec -b)	Non	Débutant
PowerShell	Oui	Oui	Non	Avancé
TCPView	Oui	Oui	Oui	Enseignant / Expert
Wireshark	Non (niveau paquet)	Non	Oui	Audit / Analyse fine

124

Lancement de la capture

🔧 Appliquer un display-filter HTTP

```
http.response.code == 200
```

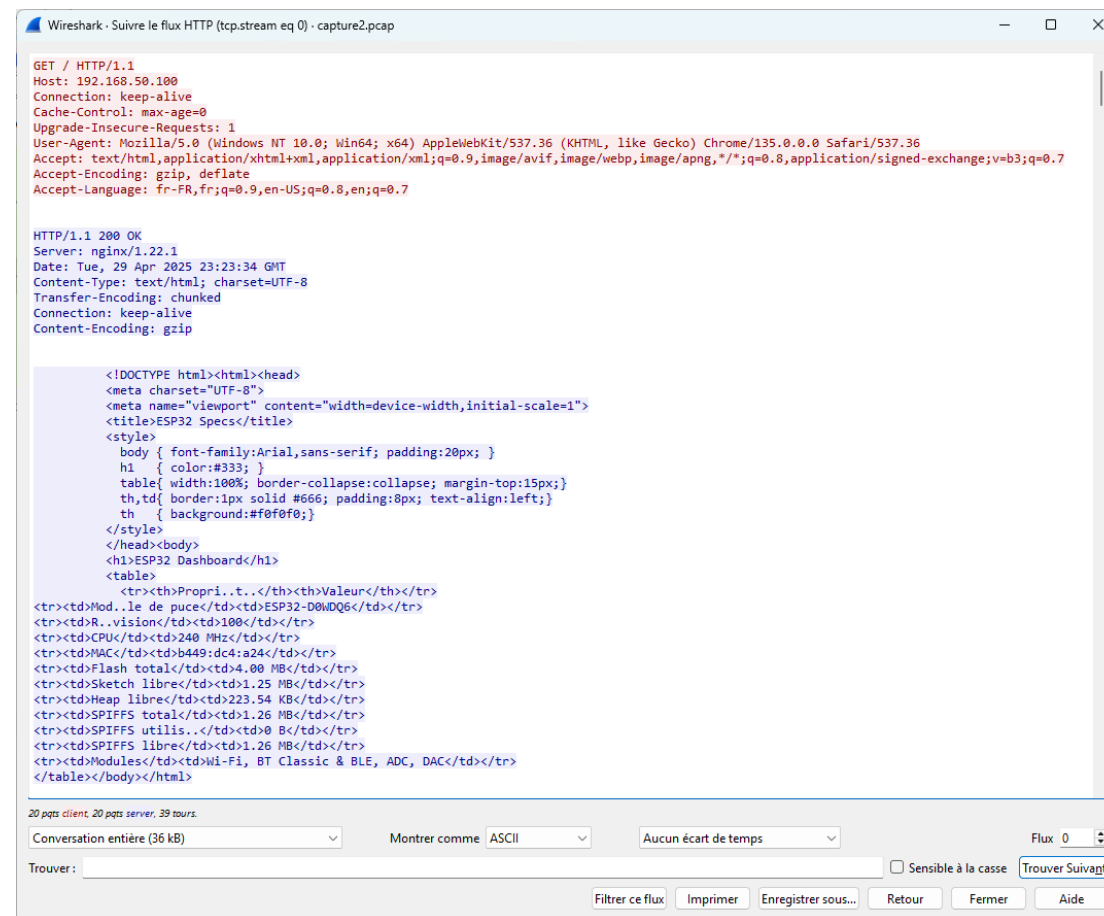


🔧 Développer la couche HTTP dans le volet “Packet Details”

- ~ Hypertext Transfer Protocol, has 2 chunks (including last chunk)
- ~ HTTP/1.1 200 OK\r\n
 - Response Version: HTTP/1.1
 - Status Code: 200
 - [Status Code Description: OK]
 - Response Phrase: OK
 - Server: nginx/1.22.1\r\n
 - Date: Tue, 29 Apr 2025 23:23:34 GMT\r\n

125

Lancement de la capture

**Analyser -> Suivre -> HTTP Flux**

Wireshark - Suivre le flux HTTP (tcp.stream eq 0) - capture2.pcap

```
GET / HTTP/1.1
Host: 192.168.50.100
Connection: keep-alive
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: fr-FR,fr;q=0.9,en-US;q=0.8,en;q=0.7

HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Tue, 29 Apr 2025 23:23:34 GMT
Content-Type: text/html; charset=UTF-8
Transfer-Encoding: chunked
Connection: keep-alive
Content-Encoding: gzip

<!DOCTYPE html><html><head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width,initial-scale=1">
<title>ESP32 Specs</title>
<style>
  body { font-family:Arial,sans-serif; padding:20px; }
  h1 { color:#333; }
  table{ width:100%; border-collapse:collapse; margin-top:15px;}
  th,td{ border:1px solid #666; padding:8px; text-align:left;}
  th { background:#f0f0f0;}
</style>
</head><body>
<h1>ESP32 Dashboard</h1>
<table>
  <tr><th>Propri. t.</th><th>Valeur</th></tr>
  <tr><td>Mod. le de puce</td><td>ESP32-D0WQ6</td></tr>
  <tr><td>R. vision</td><td>100</td></tr>
  <tr><td>CPU</td><td>240 MHz</td></tr>
  <tr><td>MAC</td><td>b449:dc4:a24</td></tr>
  <tr><td>Flash total</td><td>4.00 MB</td></tr>
  <tr><td>Sketch libre</td><td>1.25 MB</td></tr>
  <tr><td>Heap libre</td><td>223.54 KB</td></tr>
  <tr><td>SPIFFS total</td><td>1.26 MB</td></tr>
  <tr><td>SPIFFS utilis. </td><td>0 B</td></tr>
  <tr><td>SPIFFS libre</td><td>1.26 MB</td></tr>
  <tr><td>Modules</td><td>Wi-Fi, BT Classic & BLE, ADC, DAC</td></tr>
</table></body></html>
```

20 pages client, 20 pages server, 39 tours.

Conversation entière (36 kB) Montrer comme ASCII Aucun écart de temps Flux 0

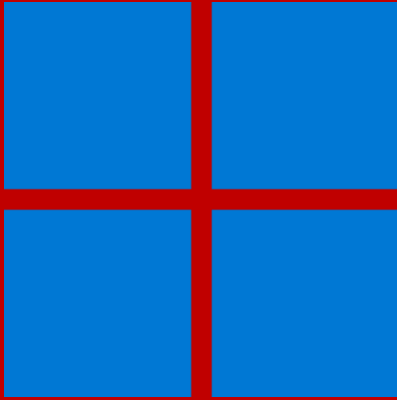
Trouver :

126 Lancement de la capture FTP

🔧 Récupération des identifiants FTP sous Wireshark



```
ftp.request.command == "USER" || ftp.request.command == "PASS"
```



NMAP



NMAP

127

Qu'est-ce que Nmap ?



Définition

Nmap (*Network Mapper*) est un outil libre et open-source qui permet de scanner des réseaux pour découvrir :

- ☐ Les hôtes actifs
- ☐ Les ports ouverts
- ☐ Les services et versions
- ☐ Les systèmes d'exploitation (OS)

129

Qu'est-ce que Nmap ?



Définition

Pourquoi l'utiliser ?

- ☐ **Sécurité** : détection de ports non autorisés
- ☐ **Administration** : inventaire des machines et services
- ☐ **Audit** : vérification de la configuration réseau

130



Installation de NMAP

Sur **Ubuntu/WSL** :

```
sudo apt update  
sudo apt install nmap
```

Vérifier la version :

```
nmap --version
```

131



Syntaxe de base

Sur **Ubuntu/WSL** :

```
nmap [options] <cible>
```

- ❑ <cible> : adresse IP (ex. 192.168.1.5), plage (192.168.1.0/24) ou nom de domaine.
- ❑ options : contrôlent le type de scan, la vitesse, le niveau de détails.

132 **Types de scans courants**

Scan	Option	Description
Ping	-sn	Détecte les hôtes vivants sans scanner ports
TCP SYN	-sS	Scan furtif (demi-ouverture)
TCP Connect	-sT	Scan complet (établit vraie connexion)
Scan UDP	-sU	Vérifie les ports UDP
Scan OS	-O	Détection du système d'exploitation
Version	-sV	Détection des versions de service



Options utiles

- ☐ **-p <ports>** : scanner ports spécifiques (-p 22,80,443) ou -p- (tous les ports)
- ☐ **-oN <fichier>** : sortie normale dans un fichier
- ☐ **-oX <fichier>** : sortie XML
- ☐ **-v / -vv** : mode verbeux (détails supplémentaires)
- ☐ **--reason** : affiche la raison pour chaque port détecté
- ☐ **--open** : n'affiche que les ports ouverts

134



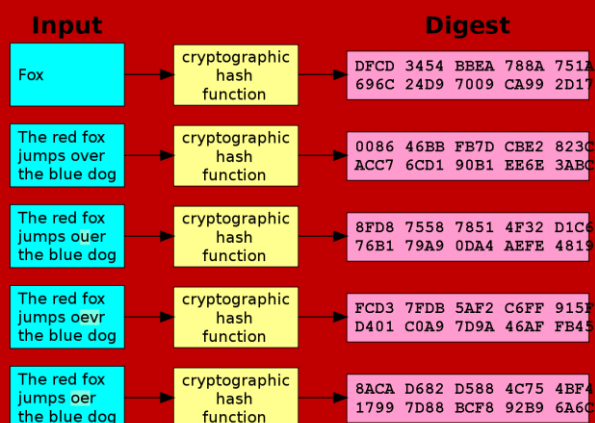
Comment faire un voisinage réseau avec nmap

```
nmap -sn 192.168.50.0/24
```

```
nmap -sn 192.168.50.0/24 | grep "Nmap scan report"
```

Proposer un **exercice** : les étudiants doivent **trouver les IP d'un serveur, d'un ESP32 et d'un client Linux sur le même réseau.**

Vérification d'un fichier à l'aide d'une fonction de hachage



1. MD5 (Message Digest Algorithm 5)
2. SHA-1 (Secure Hash Algorithm 1)
3. SHA-256 (Secure Hash Algorithm 256 bits)
4. SHA-512 (Secure Hash Algorithm 512 bits)
5. CRC32 (Cyclic Redundancy Check 32 bits)
6. HMAC (Keyed-Hash Message Authentication Code)
7. bcrypt (Adaptive Hashing Algorithm)
8. scrypt (Password-Based Key Derivation Function)
9. Argon2 (Password Hashing Function)

INCIDENT DE SECURITÉ – LA REMEDIATION

Vérification d'un fichier à l'aide d'une fonction de hachage

On nomme **fonction de hachage**, une [fonction](#) particulière qui, à partir d'une donnée fournie en entrée (*fichiers, séquences de caractère*), calcule une ***empreinte numérique*** servant à identifier rapidement la donnée initiale.

Les **fonctions de hachage** sont utilisées en informatique et en cryptographie notamment pour reconnaître rapidement des fichiers ou des mots de passe.



- Comparaison de fichiers
- Exclusion de fichiers
- Authentification de fichiers
- Identification de fichiers

**RAPPEL
IMPORTANT**

La réponse aux incidents de sécurité informatique

Indicateur de compromission pour DRIDEX

<https://www.cert.ssi.gouv.fr/cti/CERTFR-2020-CTI-005/>

malware	Dridex (botnet ID 199 ou 501)
size-in-bytes	162304
md5	7239da273d3a3bfd8d169119670bb745
sha1	f624d419671b8eef94241bd010a1ca0c22950fec
sha256	aadb5217c4c9316b90ce4eb5f2b52f72d34d426d66ce00c9addaef1654853acf
filenames	['Fiddler.exe']

malware	size-in-bytes	md5	sha1	sha256	filenames
Dridex (botnet ID 199 ou 501)	162304	7239da273d3a3bfd8d169119670bb745	f624d419671b8eef94241bd010a1ca0c22950fec	aadb5217c4c9316b90ce4eb5f2b52f72d34d426d66ce00c9addaef1654853acf	['Fiddler.exe']
Dridex (botnet ID 199 ou 501)	163328	72fe19810a9089cd1ec3ac5ddda22d3f	cecbd09b389a6f4e3ac7a81a9280e1893a6066ae	cd32a737fcb8198d43fed5a68348f983f7713f79574a710deb7759e5a1301eb	['Fiddler.exe']
Dridex (botnet ID 199 ou 501)	233472	07b0ce2dd0370392eedb0fc161c99dc7	abf30fe414f07060b95e49034f05f3e4698d71d8	13c5b33339522f8f96d091708e7a8a64b0939daa6225732352fbc44cb2950e67	['api', 'apisets', 'FQbdHGT8.exe']
Dridex (botnet ID 199 ou 501)	180224	c8bb08283e55aed151417a9ad1bc7ad9	57f8fe479206f195b630cf8232a0c0e9c5a47977	6362084f61fa6a41b8b01b7c62215ad41a2623b69572ce558c33bfaa21f0af9	['HPDJSLK', 'IA4DIPGM.EXE']
Dridex (botnet ID 199 ou 501)	1032192	6e05e84c7a993880409d7a0324c10e74	4cac8146d54c5e47ec1c31a04c3afdc9fbf209	ffb1150bbb28d53f325b00445be935cd657c1d8061ba73e91af5b343b6c0d438	['d3dx81ab.dll']
Dridex (botnet ID 199 ou 501)		63d4834f453fdd6333f0851a9d4c632			
Dridex (botnet ID 199 ou 501)	188416	0ef5c94779cd7861b5e872cd5e922311	5b4b7a6f33d3188ae5211a4432d2a5c84c1da10e	741087126c1c7edec3d0a3bc3f490723a4f410e9a278444c812e7f79013bb996	['QK9BAv2j.exe', 'HPDJSLK']
DoppelDridex (botnet ID 40300)	338944	9aa3089af1			v7Bg.binâ€™,â€™secpi15.exeâ€™]
Dridex	246816	e614a69d70			e']
Dridex (botnet ID 199)	212992	d040905225			
Dridex	273920	63fc3f7b571459c5d5e3ad1eb89f3d84	80196c93443c1bd5b5b4bba58842848366731ad	abr99a028daeb812f6f0cab633d7424ce9272drcbcebf6b518c1ebc97f872f3e7	[â€™_llkxzYVaiX.dllâ€™,â€™Wo.dllâ€™,â€™mVwEiAJObi.dllâ€™]
Dridex	1069056	369638ac700f3c41ebaba447d4048ff8	6c50a1abf9dc992e74a73279d40fb1a09368cdfc	6712500bb0de148a99ec940160d3d61850e2ce3803adca8f39e9fa8621b8ea6f	[â€™streamsâ€™,â€™streams.exeâ€™,â€™DUI70.dllâ€™]
Dridex	786432	bd5fa593ed87901f8184eaa44c0a8b8	963a57fb83ca6361624fb057058ea4fb538015dc	86bcfce2dd342e9a1c04cfc65731d40ed1c397a4ec47bd9f5b41771297d81100	[â€™streamsâ€™,â€™streams.exeâ€™,â€™UxTheme.dllâ€™]
Dridex	782336	7c9f3e0b96ce134ab482818a8ec3033a	c22fd99c995885e7656eb66cf1b043e737385cce	005e77a55b8f1bf4049d6231c2349a01d019b46f47b6930103458a2aadd1bfa6	[â€™streamsâ€™,â€™streams.exeâ€™,â€™dxgi.dllâ€™]
Dridex	266414	323f7a38cd55ef78e2e2d9e037b0171f	f5e129381be88dddec7a17dc57ce138ff1f252423	a1388cb3e6ae68a6130ae12f9db4881238c97718875a3362b6bc5788e61c6663	[â€™lbmm4rh4.exeâ€™,â€™aswBootâ€™,â€™aswBoot.exeâ€™]
Dridex	208896	6285579d7082c55871b4b9db6735255a	13cbfa1d79184d1ce8a4aef59e5c856117fd91c2	ca087f46f97cd465f46e4ccb04181e6ae7b2c751ae7fd9e262191b979728cc	[â€™VDIMEâ€™,â€™VDIME.DLLâ€™,â€™ktyaowm.binâ€™,â€™frllo.binâ€™]
Dridex	217088	c1986a52bc76c58ea099873f6464caf9	f1a543664d8872b53103e07ef659e45d3faa397c	4ad0998882a3fbd3412f0c740faeb8ef78bec4c3e566650424c0a878e6a23a	[â€™Caff54e1.exeâ€™,â€™ktyaowm.binâ€™,â€™pvmbihu.binâ€™]

Liste des indicateurs de compromission pour DRIDEX

Vérification d'un fichier à l'aide d'une fonction de hachage

138

Fichiers tests

1. Télécharger les fichiers nécessaires au cours sur Moodle **lecnam.net**
2. Décompresser le dossier
3. Ouvrir une console ou PowerShell et lister les fichiers.

```
PS F:\test_hash\TD> dir
```

```
Répertoire : F:\test_hash\TD
```

Mode	LastWriteTime		Length	Name
----	-----		-----	----
d-----	28/10/2024	00:05		sous-dossier
-a----	01/10/2024	17:48	364721	accident_Protection-Civile.webp
-a----	01/10/2024	17:52	345896	be-benevole.png
-a----	16/06/2024	15:46	193	fichier_1.txt
-a----	16/06/2024	15:44	164	fichier_2.txt
-a----	19/03/2023	12:33	2749	multipage.pdf
-a----	30/05/2024	11:16	360448	notepad.exe
-a----	30/05/2024	11:16	360448	notepad_v2.exe
-a----	01/10/2024	17:49	192850	pse-2.jpg
-a----	30/05/2024	11:16	360448	_notepad

Vérification d'un fichier à l'aide d'une fonction de hachage

139

get-filehash



Dans Windows PowerShell testons la fonction :

Sortie SHA256 (par défaut)

Le **Sha-256** est une fonction de l'algorithme Sha-2 (Secure Hash Algorithm) est une famille de fonctions de hachage qui ont été conçues par la National Security Agency des États-Unis (NSA).

```
PS F:\test_hash\TD> Get-FileHash .\notepad.exe
```

Algorithm	Hash	Path
-----	----	----
SHA256	CA29E8D8ECA84F6F1B39E0BAD771752CEBF86D7754C20B69C77AB641A9AC2767	F:\test_hash\TD\notepad.exe

Vérification d'un fichier à l'aide d'une fonction de hachage

140

get-filehash



Dans Windows PowerShell testons la fonction :

Sortie MD5 (par défaut)

Le MD5, pour **Message Digest 5**, est une fonction de hachage cryptographique qui permet d'obtenir **l'empreinte numérique d'un fichier** (on parle souvent de message). Il a été inventé par Ronald Rivest en 1991.

```
PS F:\test_hash\TD> Get-FileHash .\notepad.exe -Algorithm md5
```

Algorithm	Hash	Path
-----	----	----
MD5	FF3E29FDFAFA0E9030E2FCD71489D41D	F:\test_hash\TD\notepad.exe

```
PS F:\test_hash\TD> Get-FileHash .\notepad.exe -Algorithm md5 | Format-List
```

```
Algorithm : MD5
Hash      : FF3E29FDFAFA0E9030E2FCD71489D41D
Path      : F:\test_hash\TD\notepad.exe
```

141

Vérification d'un fichier à l'aide d'une fonction de hachage

Les changements de nom n'affectent pas la valeur du Hash

```
PS F:\test_hash\TD> Get-FileHash .\notepad.exe -Algorithm md5 | Format-List
```

```
Algorithm : MD5  
Hash      : FF3E29FDFAFA0E9030E2FCD71489D41D  
Path      : F:\test_hash\TD\notepad.exe
```

```
PS F:\test_hash\TD> Get-FileHash .\notepad_v2.exe -Algorithm md5 | Format-List
```

```
Algorithm : MD5  
Hash      : FF3E29FDFAFA0E9030E2FCD71489D41D  
Path      : F:\test_hash\TD\notepad_v2.exe
```

142

Vérification d'un fichier à l'aide d'une fonction de hachage

<https://learn.microsoft.com/fr-fr/windows/wsl/install>



```
drwxrwxrwx 1 fabrice fabrice 4096 Mar  2 17:13 .
drwxrwxrwx 1 fabrice fabrice 4096 Mar  2 17:20 ..
-rwxrwxrwx 1 fabrice fabrice 364721 Oct  1 17:48 accident_Protection-Civile.webp
-rwxrwxrwx 1 fabrice fabrice 345896 Oct  1 17:52 be-benevole.png
-rwxrwxrwx 1 fabrice fabrice 193 Jun 16 2024 fichier_1.txt
-rwxrwxrwx 1 fabrice fabrice 164 Jun 16 2024 fichier_2.txt
-rwxrwxrwx 1 fabrice fabrice 2749 Mar 19 2023 multipage.pdf
-rwxrwxrwx 1 fabrice fabrice 360448 May 30 2024 _notepad
-rwxrwxrwx 1 fabrice fabrice 360448 May 30 2024 notepad.exe
-rwxrwxrwx 1 fabrice fabrice 360448 May 30 2024 notepad_v2.exe
-rwxrwxrwx 1 fabrice fabrice 192850 Oct  1 17:49 pse-2.jpg
drwxrwxrwx 1 fabrice fabrice 4096 Oct 28 00:05 sous-dossier
```

Les changements de nom n'affectent pas la valeur du Hash

md5sum note*

```
ff3e29fdafa0e9030e2fcd71489d41d notepad.exe
ff3e29fdafa0e9030e2fcd71489d41d notepad_v2.exe
```

sha256sum note*

```
ca29e8d8eca84f6f1b39e0bad771752cebf86d7754c20b69c77ab641a9ac2767 notepad.exe
ca29e8d8eca84f6f1b39e0bad771752cebf86d7754c20b69c77ab641a9ac2767 notepad_v2.exe
```

143

Rechercher des fichiers possédant la signature



FF3E29FDFAFA0E9030E2FCD71489D41D

```
Get-ChildItem -Path "F:\test_hash\TD\" -Recurse | ForEach-Object { Get-FileHash  
-Algorithm MD5 -Path $_.FullName } | Where-Object { $_.Hash -eq  
"FF3E29FDFAFA0E9030E2FCD71489D41D" }
```

Algorithm	Hash	Path
-----	----	----
MD5	FF3E29FDFAFA0E9030E2FCD71489D41D	F:\test_hash\TD\notepad.exe
MD5	FF3E29FDFAFA0E9030E2FCD71489D41D	F:\test_hash\TD\notepad_v2.exe
MD5	FF3E29FDFAFA0E9030E2FCD71489D41D	F:\test_hash\TD_notepad
MD5	FF3E29FDFAFA0E9030E2FCD71489D41D	F:\test_hash\TD\sous-dossier\notepad_v3.log

144

Comment faire un hachage de plusieurs fichiers ?

```
find /mnt/f/test_hash/TD -type f -exec md5sum {} +  
| grep "ff3e29fdfafa0e9030e2fcd71489d41d"
```



```
ff3e29fdfafa0e9030e2fcd71489d41d /mnt/f/test_hash/TD/notepad.exe  
ff3e29fdfafa0e9030e2fcd71489d41d /mnt/f/test_hash/TD/notepad_v2.exe  
ff3e29fdfafa0e9030e2fcd71489d41d /mnt/f/test_hash/TD/sous-dossier/notepad_v3.log  
ff3e29fdfafa0e9030e2fcd71489d41d /mnt/f/test_hash/TD/_notepad
```

145

Comment faire un hachage de plusieurs fichiers ?

md5deep

```
sudo apt install md5deep -y  
  
md5deep -r /mnt/f/test_hash/TD > hashes.txt  
  
grep "ff3e29fdfafa0e9030e2fcd71489d41d" hashes.txt
```

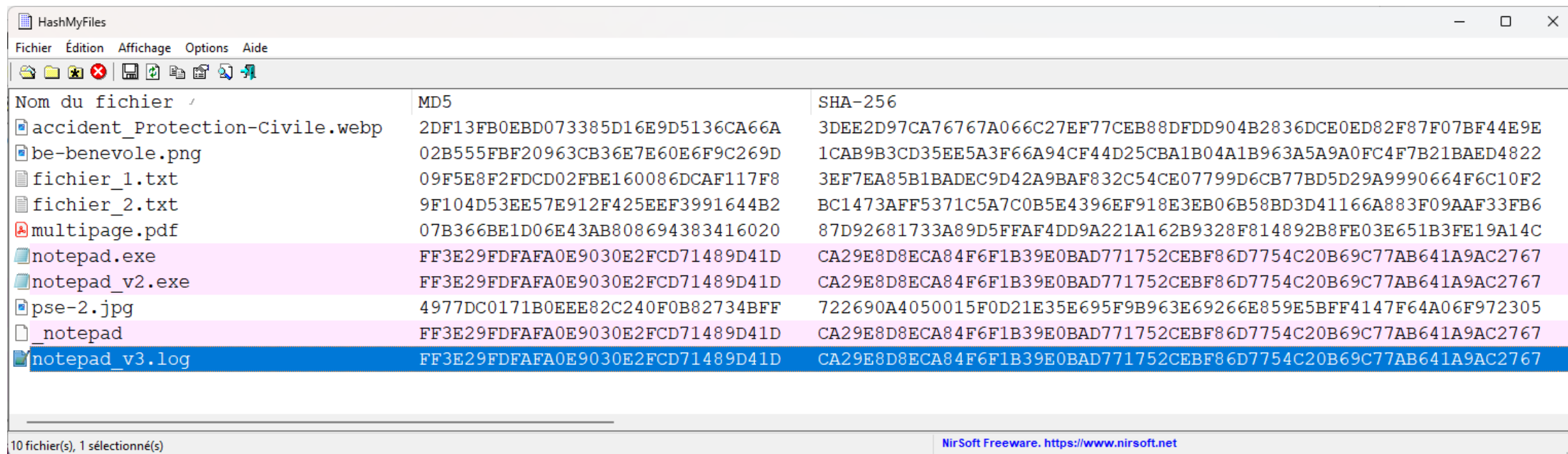


```
ff3e29fdfafa0e9030e2fcd71489d41d /mnt/f/test_hash/TD/notepad.exe  
ff3e29fdfafa0e9030e2fcd71489d41d /mnt/f/test_hash/TD/notepad_v2.exe  
ff3e29fdfafa0e9030e2fcd71489d41d /mnt/f/test_hash/TD/sous-dossier/notepad_v3.log  
ff3e29fdfafa0e9030e2fcd71489d41d /mnt/f/test_hash/TD/_notepad
```

146

Comment faire un hachage de plusieurs fichiers ?

nirsoft

SOURCES : https://www.nirsoft.net/utils/hash_my_files.html

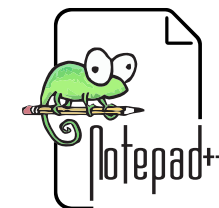
Nom du fichier	MD5	SHA-256
accident_Protection-Civile.webp	2DF13FB0EBD073385D16E9D5136CA66A	3DEE2D97CA76767A066C27EF77CEB88DFDD904B2836DCE0ED82F87F07BF44E9E
be-benevole.png	02B555FBF20963CB36E7E60E6F9C269D	1CAB9B3CD35EE5A3F66A94CF44D25CBA1B04A1B963A5A9A0FC4F7B21BAED4822
fichier_1.txt	09F5E8F2FDCD02FBE160086DCAF117F8	3EF7EA85B1BADEC9D42A9BAF832C54CE07799D6CB77BD5D29A9990664F6C10F2
fichier_2.txt	9F104D53EE57E912F425EEF3991644B2	BC1473AFF5371C5A7C0B5E4396EF918E3EB06B58BD3D41166A883F09AAF33FB6
multipage.pdf	07B366BE1D06E43AB808694383416020	87D92681733A89D5FFAF4DD9A221A162B9328F814892B8FE03E651B3FE19A14C
notepad.exe	FF3E29FDFAFA0E9030E2FCD71489D41D	CA29E8D8ECA84F6F1B39E0BAD771752CEBF86D7754C20B69C77AB641A9AC2767
notepad_v2.exe	FF3E29FDFAFA0E9030E2FCD71489D41D	CA29E8D8ECA84F6F1B39E0BAD771752CEBF86D7754C20B69C77AB641A9AC2767
pse-2.jpg	4977DC0171B0EEE82C240F0B82734BFF	722690A4050015F0D21E35E695F9B963E69266E859E5BFF4147F64A06F972305
_notepad	FF3E29FDFAFA0E9030E2FCD71489D41D	CA29E8D8ECA84F6F1B39E0BAD771752CEBF86D7754C20B69C77AB641A9AC2767
notepad_v3.log	FF3E29FDFAFA0E9030E2FCD71489D41D	CA29E8D8ECA84F6F1B39E0BAD771752CEBF86D7754C20B69C77AB641A9AC2767

10 fichier(s), 1 sélectionné(s)

NirSoft Freeware. <https://www.nirsoft.net>

Comparaison du contenu d'un fichier texte

Notepad++ v8.5.2



Download 64-bit x64

- [Installer](#) | [GPG Signature](#)



[SHA-256 digests of binary packages](#)

```
4fea8ce3b4b113fd4b9ffc32b1cc60f078aa33a722121b0c6eef9b672cb64637
884ee52151a87bd7e1f0bcbfec151e652f8e29640141da1f6b7f3e3c5c558cf1
572811bf01a9112c7414b783861da34b2b93f3de298e8455dafb484d19b11f4b
c09cb7c049f9e14459c39a7a36a0ba2ffb35a8d0e2f1b73a29fcf05c32dd7b05
c215cf3cd031ef5b468dd69d3dbae0fb64261b75bc659b465f4f51b23be38f1f
3925128ddf7b306a333d4bd484966bee5f6e0c0e8615533c8a5f970e25779a0b
384f80c0eeffee819d42859156f384b4da976ee7933e9b0abd593b887414b67e
b589c8daf5b872e13703a28feae5b8aec40e1ce1f38769bbfaf198be1dc52ac
c7e2e87e77c01d2f6dfa796c9722a83b11bedcd7217cb60ce05b4dafa3487d1c
1f13ad0de96555454bd362f75833c5ebdadfac2936dca1579deef834d3918a1c
5cd628de3bb5d6468f8bf8fb664312b2f82acb62271bc84419728075aaafd883b
9092255c1fc60b997497043d1c4f69f64ee25830e32677cddba314d45f2e390c
```

```
npp.8.5.2.Installer.arm64.exe
npp.8.5.2.Installer.exe
npp.8.5.2.Installer.x64.exe
npp.8.5.2.portable.7z
npp.8.5.2.portable.arm64.7z
npp.8.5.2.portable.arm64.zip
npp.8.5.2.portable.minimalist.7z
npp.8.5.2.portable.minimalist.arm64.7z
npp.8.5.2.portable.minimalist.x64.7z
npp.8.5.2.portable.x64.7z
npp.8.5.2.portable.x64.zip
npp.8.5.2.portable.zip
```

Download source code

[Download Notepad++ source code of current version
and/or check sha-256 digests for binary packages on
GitHub](#)

SOURCES : <https://notepad-plus-plus.org/downloads/>

Comparaison du contenu d'un fichier texte



Commande : fc

```
PS F:\test_hash\TD> fc.exe .\fichier_1.txt .\fichier_2.txt
Comparaison des fichiers .\fichier_1.txt et .\FICHIER_2.TXT
***** .\fichier_1.txt
Lorem ipsum dolor sit amet, consectetur adipiscing elit.
Sed non risus.
Suspendisse lectus tortor, dignissim sit amet, adipiscing nec, ultricies sed, dolor.
Cras elementum ultrices diam.
***** .\FICHIER_2.TXT
Lorem ipsum dolor sit amet, consectetur adipiscing elit.

Sed non risus.

Suspendisse lectus tortor, dignissim sit amet, adipiscing nec, ultricies sed, dolor.
*****
```

Commande : comp

R1 – Fichier texte

```
H:\>comp text_01.txt text_02.txt
Comparaison de text_01.txt et text_02.txt...
Les fichiers sont de taille différente.
```

R2 – Fichier binaire

```
F:\test_hash\TD>comp notepad.exe notepad_v2.exe
Comparaison de notepad.exe et notepad_v2.exe...
Comparaison des fichiers OK
```

Comparaison du contenu d'un fichier texte



```
Compare-Object -ReferenceObject (Get-Content .\fichier_1.txt) -DifferenceObject  
(Get-Content .\fichier_2.txt)
```

```
PS F:\test_hash\TD> Compare-Object -ReferenceObject (Get-Content .\fichier_1.txt) -DifferenceObject (Get-Content .\fichier_2.txt)
```

InputObject	SideIndicator
	=>
	=>
Suspendisse lectus tortor, dignissim sit amet, adipiscing nec, ultricies sed, dolor.	=>
Suspendisse lectus tortor, dignissim sit amet, adipiscing nec, ultricies sed, dolor.	<=
Cras elementum ultrices diam.	<=

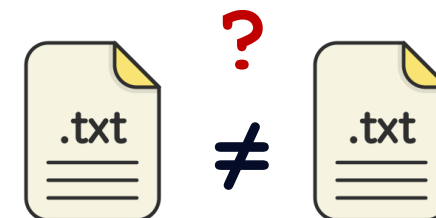
150

Comparaison du contenu d'un fichier texte

```
diff text_01.txt text_02.txt
```

Sélection fabrice@TsunamiDream: /mnt/h

```
fabrice@TsunamiDream:/mnt/h$ diff text_01.txt text_02.txt
1,3c1,3
< Lorem ipsum dolor sit amet, consectetur adipiscing elit.
< Sed non risus.
< Suspendisse lectus tortor, dignissim sit amet, adipiscing nec, ultricies sed, dolor.
---
> Lorem ipsum dolir sit amet, consectetur adipiscing elit.
> Sad non risus.
> Suspendisse lectus tortor, dignissim sat atet, adipiscing nec, ultricies sed, dolor.
5c5
< Maecenas ligula massa, varius a, semper congue, euismod non, mi.
---
> Maecenas ligula massa, varius a, samper congue, euismod non, mi.
7c7
< Duis semper.
\ No newline at end of file
---
> Dois semper.
\ No newline at end of file
```



```
diff -q text_01.txt text_02.txt
```

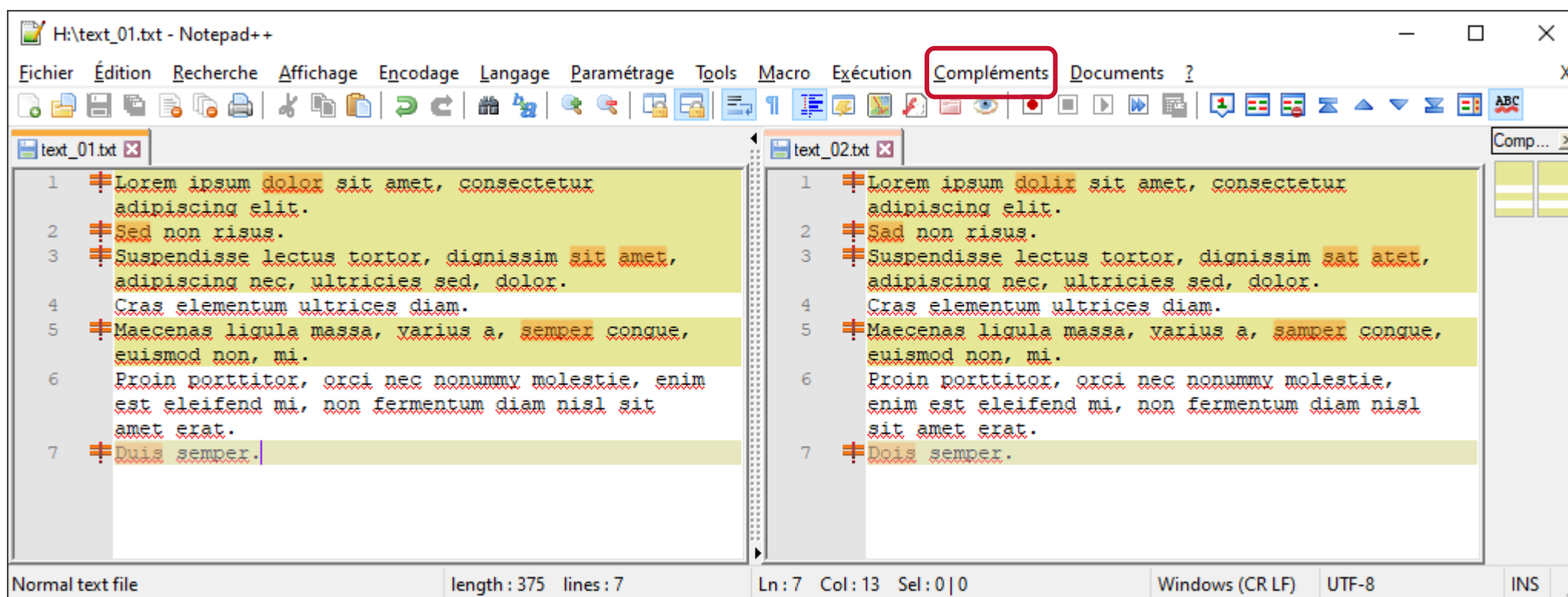
```
Files text_01.txt and text_02.txt differ
```

7C7 Cela indique qu'il y a une différence à la ligne 7. La ligne originale (text_01.txt) est indiquée avec « < » et la ligne modifiée (text_02.txt) est indiquée avec « > » .
Vous pouvez voir que la ligne 2 " Duis semper." dans le text_01.txt a été modifiée pour devenir " Dois semper." dans le text_02.txt.



151

Comparaison du contenu d'un fichier texte



H:\text_01.txt - Notepad++

Fichier Édition Recherche Affichage Encodage Langage Paramétrage Tools Macro Exécution **Compléments** Documents ?

text_01.txt x

```
1 Lorem ipsum dolor sit amet, consectetur  
adipiscing elit.  
2 Sed non risus.  
3 Suspendisse lectus tortor, dignissim sit amet,  
adipiscing nec, ultricies sed, dolor.  
4 Cras elementum ultrices diam.  
5 Maecenas ligula massa, varius a, semper congue,  
euismod non, mi.  
6 Proin porttitor, orci nec nonummy molestie, enim  
est eleifend mi, non fermentum diam nisl sit  
amet erat.  
7 Duis semper.
```

Normal text file length : 375 lines : 7

text_02.txt x

```
1 Lorem ipsum dolir sit amet, consectetur  
adipiscing elit.  
2 Sad non risus.  
3 Suspendisse lectus tortor, dignissim sat atet,  
adipiscing nec, ultricies sed, dolor.  
4 Cras elementum ultrices diam.  
5 Maecenas ligula massa, varius a, samper congue,  
euismod non, mi.  
6 Proin porttitor, orci nec nonummy molestie,  
enim est eleifend mi, non fermentum diam nisl  
sit amet erat.  
7 Dois semper.
```

Ln : 7 Col : 13 Sel : 0 | 0 Windows (CR LF) UTF-8 INS

SOURCES : <https://notepad-plus-plus.org/downloads/>

152

Comparaison du contenu d'un fichier texte

Télécharger WinMerge

La manière la plus simple d'installer WinMerge est de le télécharger et exécuter l'installateur. Lisez le [manuel en ligne](#) pour vous apprendre à l'utiliser.

WinMerge 2.16.30

La version actuelle de WinMerge est **2.16.30** et a été publiée le **2023-04-27**. Pour une information détaillée des nouveautés, lisez le [journal des modifications](#) et les [notes de versions](#).



Télécharger	Size	Type	Format
WinMerge-2.16.30-x64-Setup.exe	7.94 MB	Installeur	EXE

SHA-256 Checksums

WinMerge-2.16.30-Setup.exe

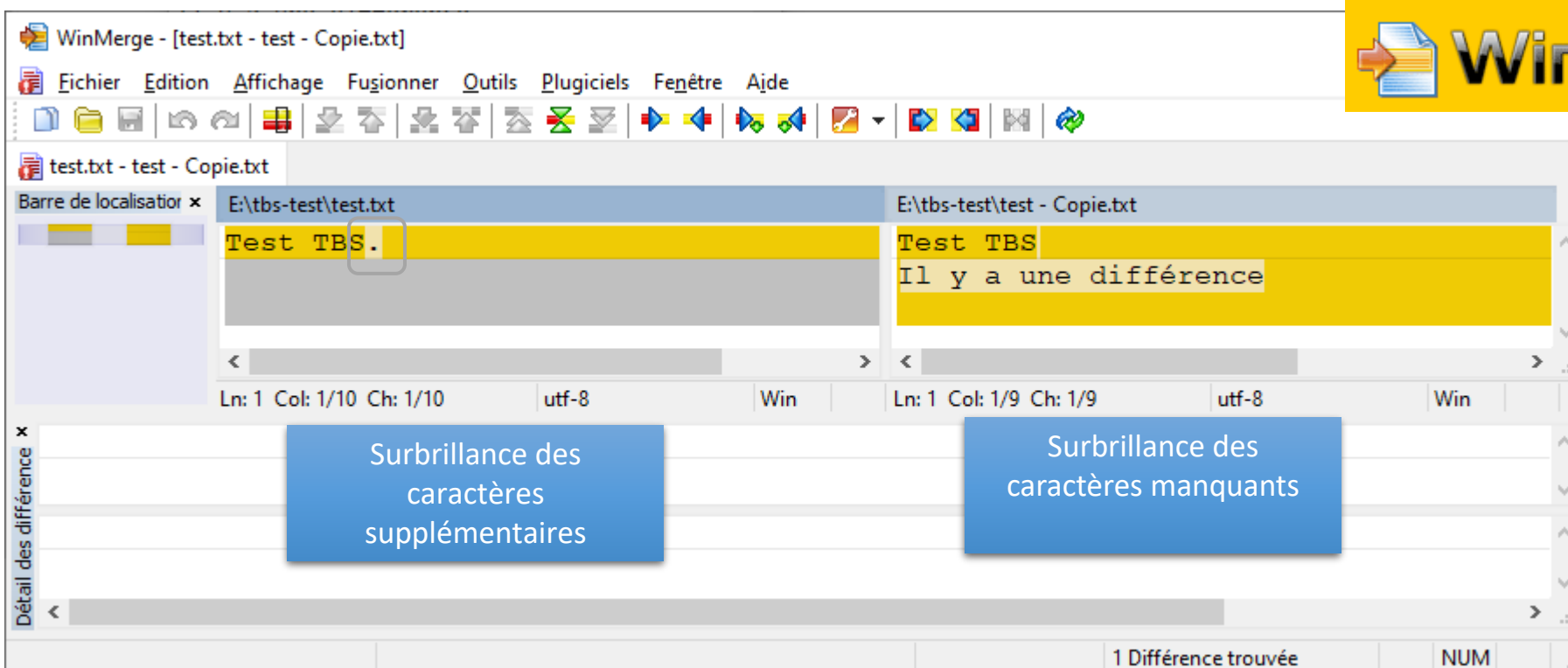
6fc6c6179fa1e6b2629ee40633193035d6e0f433c91891787368e6f92872f5c2

WinMerge-2.16.30-x64-Setup.exe

abb01254f569f6723656aa6c7c9eba0b4214357049c1934acc67fd04f9836111

SOURCES : <https://winmerge.org/downloads/?lang=fr/>

Comparaison du contenu d'un fichier texte



SOURCES : <https://winmerge.org/downloads/?lang=fr/>

154

Loki



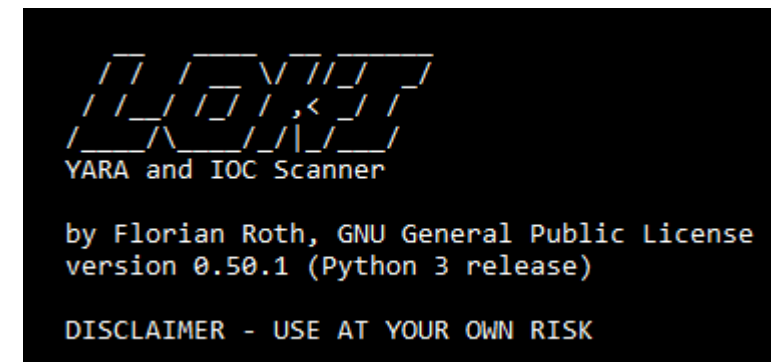
Simple IOC and YARA Scanner

Loki - Simple IOC est un outil open source qui permet de rechercher des Indicateurs d'Attaque (IOC) dans des fichiers journaux, des fichiers ou tout autre flux de données.

loki_0.50.1

Mise à jour
des signatures

Nom	Type	Taille compressée
config	Dossier de fichiers	
docs	Dossier de fichiers	
plugins	Dossier de fichiers	
tools	Dossier de fichiers	
LICENSE	Fichier	12 Ko
loki.exe	Application	13 574 Ko
loki-upgrader.exe	Application	12 369 Ko
README.md	Fichier MD	6 Ko
requirements.txt	Document texte	1 Ko

Mise à jour
des signatures

Nom	Modifié le	Type
config	15/05/2023 00:37	Dossier de fichiers
docs	15/05/2023 00:37	Dossier de fichiers
plugins	15/05/2023 00:37	Dossier de fichiers
signature-base	15/05/2023 00:38	Dossier de fichiers
tools	15/05/2023 00:37	Dossier de fichiers

<https://github.com/Neo23x0/Loki>

Loki



Simple IOC and YARA Scanner

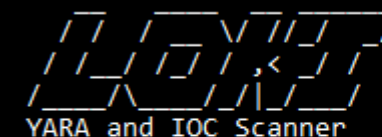
```
Administrateur : Windows PowerShell
PS E:\loki_0.50.1\loki> .\loki.exe -h
usage: loki.exe [-h] [-p path] [-s kilobyte] [-l log-file] [-r remote-loghost]
               [-t remote-syslog-port] [-a alert-level] [-w warning-level]
               [-n notice-level] [--allhds] [--alldrives] [--printall]
               [--allreasons] [--noprocsan] [--nofilescan] [--vulnchecks]
               [--nolevcheck] [--scriptanalysis] [--rootkit] [--noindicator]
               [--dontwait] [--intense] [--csv] [--onlyrelevant] [--nolog]
               [--update] [--debug] [--maxworkingset MAXWORKINGSET] [--syslogtcp]
               [--logfolder log-folder] [--nopesieve] [--pesieveshellc]
               [--python PYTHON] [--nolisten] [--excludeprocess EXCLUDEPROCESS]
               [--force] [--version]
```

Loki - Simple IOC Scanner

```
options:
-h, --help                show this help message and exit
-p path                    Path to scan
-s kilobyte                Maximum file size to check in KB (default 5000 KB)
-l log-file                Log file
-r remote-loghost          Remote syslog system
-t remote-syslog-port      Remote syslog port
-a alert-level             Alert score
-w warning-level           Warning score
-n notice-level            Notice score
--allhds                   Scan all local hard drives (Windows only)
--alldrives                Scan all drives (including network drives and removable
                           media)
--printall                 Print all files that are scanned
--allreasons               Print all reasons that caused the score
--noprocsan                Skip the process scan
--nofilescan               Skip the file scan
--vulnchecks               Run the vulnerability checks
--nolevcheck               Skip the Levenshtein distance check
--scriptanalysis            Statistical analysis for scripts to detect obfuscated code
                           (beta)
--rootkit                  Skip the rootkit check
--noindicator              Do not show a progress indicator
--dontwait                 Do not wait on exit
--intense                  Intense scan mode (also scan unknown file types and all
                           extensions)
--csv                      Write CSV log format to STDOUT (machine processing)
--onlyrelevant             Only print warnings or alerts
--nolog                    Don't write a local log file
--update                   Update the signatures from the "signature-base" sub
                           repository
--debug                    Debug output
--maxworkingset MAXWORKINGSET
                           Maximum working set size of processes to scan (in MB,
                           default 100 MB)
--syslogtcp                Use TCP instead of UDP for syslog logging
--logfolder log-folder     Folder to use for logging when log file is not specified
--nopesieve                Do not perform pe-sieve scans
--pesieveshellc            Perform pe-sieve shellcode scan
--python PYTHON            Override default python path
--nolisten                 Do not show listening connections
--excludeprocess EXCLUDEPROCESS
                           Specify an executable name to exclude from scans, can be
                           used multiple times
--force                    Force the scan on a certain folder (even if excluded with
                           hard exclude in LOKI's code
--version                  Shows welcome text and version of loki, then exit
```


Loki

Simple IOC and YARA Scanner



by Florian Roth, GNU General Public License
version 0.50.1 (Python 3 release)

DISCLAIMER - USE AT YOUR OWN RISK

```
PS E:\loki_0.50.1\loki> .\loki.exe
```



by Florian Roth, GNU General Public License
version 0.50.1 (Python 3 release)

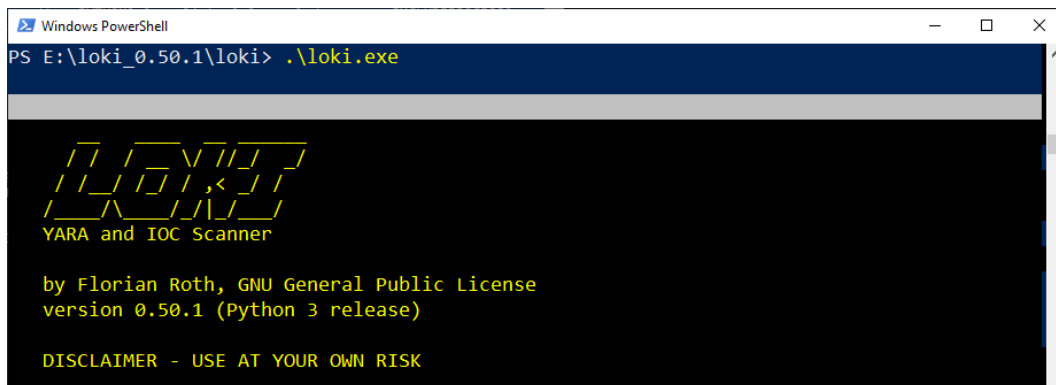
DISCLAIMER - USE AT YOUR OWN RISK

```
[NOTICE] Starting Loki Scan VERSION: 0.50.1 SYSTEM: TSUNAMIDREAM TIME: 20230514T23:47:57Z PLATFORM: 10 10.0.19045 SP0 Multiprocessor Free PROC: Intel64 Family 6 Model 94 Stepping 3, GenuineIntel ARCH: 64bit WindowsPE
[NOTICE] PE-Sieve successfully initialized BINARY: E:\loki_0.50.1\loki\tools\pe-sieve64.exe SOURCE: https://github.com/hasherezade/pe-sieve
[INFO] File Name Characteristics initialized with 3606 regex patterns
[INFO] C2 server indicators initialized with 1734 elements
[INFO] Malicious MD5 Hashes initialized with 19242 hashes
[INFO] Malicious SHA1 Hashes initialized with 7783 hashes
[INFO] Malicious SHA256 Hashes initialized with 23567 hashes
[INFO] False Positive Hashes initialized with 0 hashes
[INFO] Processing YARA rules folder E:\loki_0.50.1\loki\signature-base\yara
[INFO] Initializing all YARA rules at once (composed string of all rule files)
[INFO] Initialized 906 Yara rules
[INFO] Current user has admin rights - very good
[INFO] Setting LOKI process with PID: 24804 to priority IDLE
```

Loki se lance avec ces paramètres
par défaut c'est dire **scan complet**
(processus et lecteurs),



Simple IOC and YARA Scanner



Pour un **scan avec les processus** il est nécessaire de lancer **Loki en mode administrateur**.

En mode utilisateur, seuls les lecteurs sont observés

```
[NOTICE] Starting Loki Scan VERSION: 0.50.1 SYSTEM: TSUNAMIDREAM TIME: 20230515T00:03:33Z
PLATFORM: 10 10.0.19045 SP0 Multiprocessor Free PROC: Intel64 Family 6 Model 94 Stepping 3
, GenuineIntel ARCH: 64bit WindowsPE
[NOTICE] PE-Sieve successfully initialized BINARY: E:\loki_0.50.1\loki\tools\pe-sieve64.exe
e SOURCE: https://github.com/hasherezade/pe-sieve
[INFO] File Name Characteristics initialized with 3606 regex patterns
[INFO] C2 server indicators initialized with 1734 elements
[INFO] Malicious MD5 Hashes initialized with 19242 hashes
[INFO] Malicious SHA1 Hashes initialized with 7783 hashes
[INFO] Malicious SHA256 Hashes initialized with 23567 hashes
[INFO] False Positive Hashes initialized with 0 hashes
[INFO] Processing YARA rules folder E:\loki_0.50.1\loki\signature-base\yara
[INFO] Initializing all YARA rules at once (composed string of all rule files)
[INFO] Initialized 906 Yara rules
[NOTICE] Program should be run 'as Administrator' to ensure all access rights to process m
emory and file objects.
[INFO] Setting LOKI process with PID: 36516 to priority IDLE
[NOTICE] Skipping process memory check. User has no admin rights.
[INFO] Scanning Path C:\ ...
```

158

Loki



Simple IOC and YARA Scanner

A screenshot of a Windows PowerShell terminal window titled "Windows PowerShell". The command prompt shows the execution of a script: `PS E:\loki_0.50.1\loki> .\loki.exe -p H:\`. Below the command prompt, there is a large ASCII art logo consisting of several rows of backslashes and forward slashes forming a stylized shape. Underneath the logo, the text reads:
YARA and IOC Scanner

by Florian Roth, GNU General Public License
version 0.50.1 (Python 3 release)

DISCLAIMER - USE AT YOUR OWN RISK

Loki lancer en mode utilisateur

Le système semble sain

```
[NOTICE] Starting Loki Scan VERSION: 0.50.1 SYSTEM: TSUNAMIDREAM TIME: 20230515T00:10:52Z
PLATFORM: 10 10.0.19045 SP0 Multiprocessor Free PROC: Intel64 Family 6 Model 94 Stepping 3
, GenuineIntel ARCH: 64bit WindowsPE
[NOTICE] PE-Sieve successfully initialized BINARY: E:\loki_0.50.1\loki\tools\pe-sieve64.exe
e SOURCE: https://github.com/hasherezade/pe-sieve
[INFO] File Name Characteristics initialized with 3606 regex patterns
[INFO] C2 server indicators initialized with 1734 elements
[INFO] Malicious MD5 Hashes initialized with 19241 hashes
[INFO] Malicious SHA1 Hashes initialized with 7783 hashes
[INFO] Malicious SHA256 Hashes initialized with 23567 hashes
[INFO] False Positive Hashes initialized with 0 hashes
[INFO] Processing YARA rules folder E:\loki_0.50.1\loki\signature-base\yara
[INFO] Initializing all YARA rules at once (composed string of all rule files)
[INFO] Initialized 906 Yara rules
[NOTICE] Program should be run 'as Administrator' to ensure all access rights to process m
emory and file objects.
[INFO] Setting LOKI process with PID: 4108 to priority IDLE
[NOTICE] Skipping process memory check. User has no admin rights.
[INFO] Scanning Path H:\ ...
[NOTICE] Results: 0 alerts, 0 warnings, 4 notices
[RESULT] SYSTEM SEEMS TO BE CLEAN.
[INFO] Please report false positives via https://github.com/Neo23x0/signature-base
[NOTICE] Finished LOKI Scan SYSTEM: TSUNAMIDREAM TIME: 20230515T00:10:55Z
```

159

Loki

Simple IOC and YARA Scanner



Ajuter une
signature

Nom	Modifié le	Type
config	15/05/2023 00:37	Dossier de fichiers
docs	15/05/2023 00:37	Dossier de fichiers
plugins	15/05/2023 00:37	Dossier de fichiers
signature-base	15/05/2023 00:38	Dossier de fichiers
tools	15/05/2023 00:37	Dossier de fichiers

Nom	Modifié le	Type
iocs	15/05/2023 00:38	Dossier de fichiers
misc	15/05/2023 00:38	Dossier de fichiers
yara	15/05/2023 00:38	Dossier de fichiers

Modification du fichier
« **hash-iocs.txt** »

Nom	Modifié le	Type
c2-iocs.txt	15/05/2023 00:38	Document texte
filename-iocs.txt	15/05/2023 00:38	Document texte
hash-iocs.txt	15/05/2023 02:08	Document texte
keywords.txt	15/05/2023 00:38	Document texte
otx-hash-iocs.txt	15/05/2023 00:38	Document texte
README.txt	15/05/2023 00:38	Document texte

160

Loki



Simple IOC and YARA Scanner

hash-iocs.txt

Ajouter une
signature

Dans le fichier
« **hash-iocs.txt** »
Nous ajoutons la ligne
hash;commentaire

```
#
# LOKI CUSTOM EVIL HASHES
# This file contains MD5, SHA1 and SHA256 hashes and a short info like file name
# or hash origin
#
# FORMAT -----
#
# MD5;COMMENT
# SHA1;COMMENT
# SHA256;COMMENT
#
# EXAMPLES -----
#
# 0c2674c3a97c53082187d930efb645c2;DEEP PANDA Sakula Malware - http://goo.gl/R3e6eG
# 000c907d39924de62b5891f8d0e03116;The Darkhotel APT http://goo.gl/DuS7WS
# c03318cb12b827c03d556c8747b1e323225df97bdc4258c2756b0d6a4fd52b47;Operation SMN
# Hashes http://goo.gl/bfmF8B - Zxshell
#
# 563d1512178cecl1f6a73c98d565c98fa;Cygwin nc.exe example
#
# 27f71b12cb585541885a31be22f61c83;notepad.exe Compromis
# 4fef5e34143e646dbf9907c4374276f5;securelist.com https://goo.gl/nkbFwv
# 5bef35496fcbdbe841c82f4dlab8b7c2;securelist.com https://goo.gl/nkbFwv
```

Loki



Simple IOC and YARA Scanner

```
Windows PowerShell
PS E:\loki_0.50.1\loki> .\loki.exe -p H:\
```

YARA and IOC Scanner

by Florian Roth, GNU General Public License
version 0.50.1 (Python 3 release)

DISCLAIMER - USE AT YOUR OWN RISK

Loki lancer en mode utilisateur

```
[NOTICE] Starting Loki Scan VERSION: 0.50.1 SYSTEM: TSUNAMIDREAM TIME: 20230515T00:10:52Z
PLATFORM: 10 10.0.19045 SP0 Multiprocessor Free PROC: Intel64 Family 6 Model 94 Stepping 3
, GenuineIntel ARCH: 64bit WindowsPE
[NOTICE] PE-Sieve successfully initialized BINARY: E:\loki_0.50.1\loki\tools\pe-sieve64.exe
e SOURCE: https://github.com/hasherezade/pe-sieve
[INFO] File Name Characteristics initialized with 3606 regex patterns
[INFO] C2 server indicators initialized with 1734 elements
[INFO] Malicious MD5 Hashes initialized with 19241 hashes
[INFO] Malicious SHA1 Hashes initialized with 7783 hashes
[INFO] Malicious SHA256 Hashes initialized with 23567 hashes
[INFO] False Positive Hashes initialized with 0 hashes
[INFO] Processing YARA rules folder E:\loki_0.50.1\loki\signature-base\yara
[INFO] Initializing all YARA rules at once (composed string of all rule files)
[INFO] Initialized 906 Yara rules
[NOTICE] Program should be run 'as Administrator' to ensure all access rights to process m
emory and file objects.
[INFO] Setting LOKI process with PID: 4108 to priority IDLE
[NOTICE] Skipping process memory check. User has no admin rights.
[INFO] Scanning Path H:\ ...
```

Simple IOC and YARA Scanner



by Florian Roth, GNU General Public License
version 0.50.1 (Python 3 release)

DISCLAIMER - USE AT YOUR OWN RISK

loki_TSUNAMIDREAM_2023-05-15_02-29-59.log

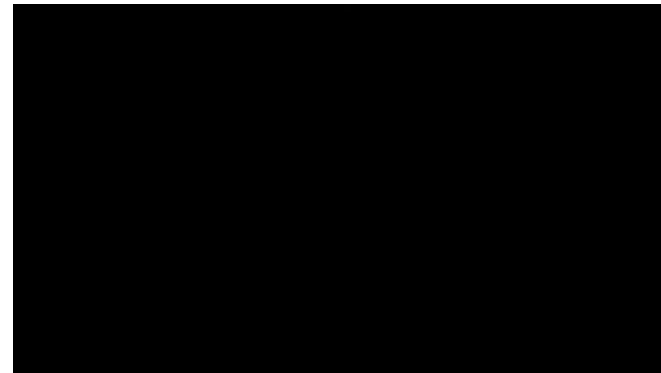
```
[NOTICE] Program should be run 'as Administrator' to ensure all access rights to process memory and file objects.
[INFO] Setting LOKI process with PID: 28808 to priority IDLE
[NOTICE] Skipping process memory check. User has no admin rights.
[INFO] Scanning Path H:\ ...
[ALERT]
FILE: H:\notepad.exe SCORE: 100 TYPE: EXE SIZE: 201216
FIRST_BYTES: 4d5a90000300000004000000ffff0000b8000000 / <filter object at 0x000001EDE74A3DF0>
MD5: 27f71b12cb585541885a31be22f61c83
SHA1: d05defe2c8efef10ed5f1361760fa0ae41fa79f5
SHA256: f9d9b9ded9a67aa3cfdbd5002f3b524b265c4086c188e1be7c936ab25627bf01 CREATED: Sun May 14 18:22:40 2023 MODIFIED: Fri Aug 12 11:29:14 2022 ACCESSED: Sun May 14 18:22:40 2023
REASON_1: Malware Hash TYPE: MD5 HASH: 27f71b12cb585541885a31be22f61c83 SUBSCORE: 100 DESC: notepad.exe Compromis
[ALERT]
FILE: H:\notepad - Copie.exe SCORE: 100 TYPE: EXE SIZE: 201216
FIRST_BYTES: 4d5a90000300000004000000ffff0000b8000000 / <filter object at 0x000001EDE74A3E20>
MD5: 27f71b12cb585541885a31be22f61c83
SHA1: d05defe2c8efef10ed5f1361760fa0ae41fa79f5
SHA256: f9d9b9ded9a67aa3cfdbd5002f3b524b265c4086c188e1be7c936ab25627bf01 CREATED: Sun May 14 22:47:48 2023 MODIFIED: Fri Aug 12 11:29:14 2022 ACCESSED: Sun May 14 22:47:48 2023
REASON_1: Malware Hash TYPE: MD5 HASH: 27f71b12cb585541885a31be22f61c83 SUBSCORE: 100 DESC: notepad.exe Compromis
[ALERT]
FILE: H:\tools\notepad SCORE: 100 TYPE: EXE SIZE: 201216
FIRST_BYTES: 4d5a90000300000004000000ffff0000b8000000 / <filter object at 0x000001EDE74A3E80>
MD5: 27f71b12cb585541885a31be22f61c83
SHA1: d05defe2c8efef10ed5f1361760fa0ae41fa79f5
SHA256: f9d9b9ded9a67aa3cfdbd5002f3b524b265c4086c188e1be7c936ab25627bf01 CREATED: Sun May 14 18:25:04 2023 MODIFIED: Fri Aug 12 11:29:14 2022 ACCESSED: Sun May 14 18:25:04 2023
REASON_1: Malware Hash TYPE: MD5 HASH: 27f71b12cb585541885a31be22f61c83 SUBSCORE: 100 DESC: notepad.exe Compromis
[NOTICE] Results: 3 alerts, 0 warnings, 4 notices
[RESULT] Indicators detected!
[RESULT] Loki recommends checking the elements on virustotal.com or Google and triage with a professional tool like THOR https://nexttron-systems.com/thor in corporate networks.
[INFO] Please report false positives via https://github.com/Neo23x0/signature-base
[NOTICE] Finished LOKI Scan SYSTEM: TSUNAMIDREAM TIME: 20230515T00:30:03Z
```




163



ATT&CK™



Qu'est-ce que MITRE ATT&CK et quelle est son utilité?

MITRE est une société à but non lucratif créée en 1958 dont la mission est de « résoudre les problèmes pour un monde plus sûr ».

Cet objectif est atteint en partie grâce à la nouvelle base de connaissances de l'organisation, connue sous le nom de MITRE ATT&CK, qui signifie « **Adversarial Tactics, Techniques, and Common Knowledge** » (**Tactiques, techniques et connaissances de base des adversaires**).

MITRE
ATT&CK™

165

Qu'est-ce que MITRE ATT&CK et quelle est son utilité?

La plateforme organise et catégorise divers types de **tactiques, techniques et procédures (TTP)** utilisées par les acteurs de la menace (**Red Team**) dans le monde numérique, visant à aider les organisations (**blue Team**) à identifier les lacunes dans leurs cyberdéfenses.

- Les tactiques
- Les techniques
- Les groupes d'attaquants
- Les outils utilisés par les attaquants
- Les mitigations (réductions, adoucissements des dommages)
- La matrice de description des phases de l'attaque



Qu'est-ce que MITRE ATT&CK et quelle est son utilité?

166

Les tactiques

1. **Reconnaissance (TA0043)** – L'attaquant **collecte des informations** sur la cible avant d'attaquer
(ex. : scan réseau, phishing).
2. **Développement des ressources (TA0042)** – L'attaquant prépare **son infrastructure** : achat de domaines, création de malwares, vol d'identifiants.
3. **Accès initial (TA0001)** – L'attaquant obtient une **première entrée** : exploitation d'une faille, phishing, compromission d'un compte.
4. **Exécution (TA0002)** – L'attaquant **exécute du code malveillant** sur la machine cible pour déployer son attaque.
5. **Persistance (TA0003)** – L'attaquant met en place des **mécanismes** pour **garder l'accès** même après un redémarrage.

Qu'est-ce que MITRE ATT&CK et quelle est son utilité?

Les tactiques

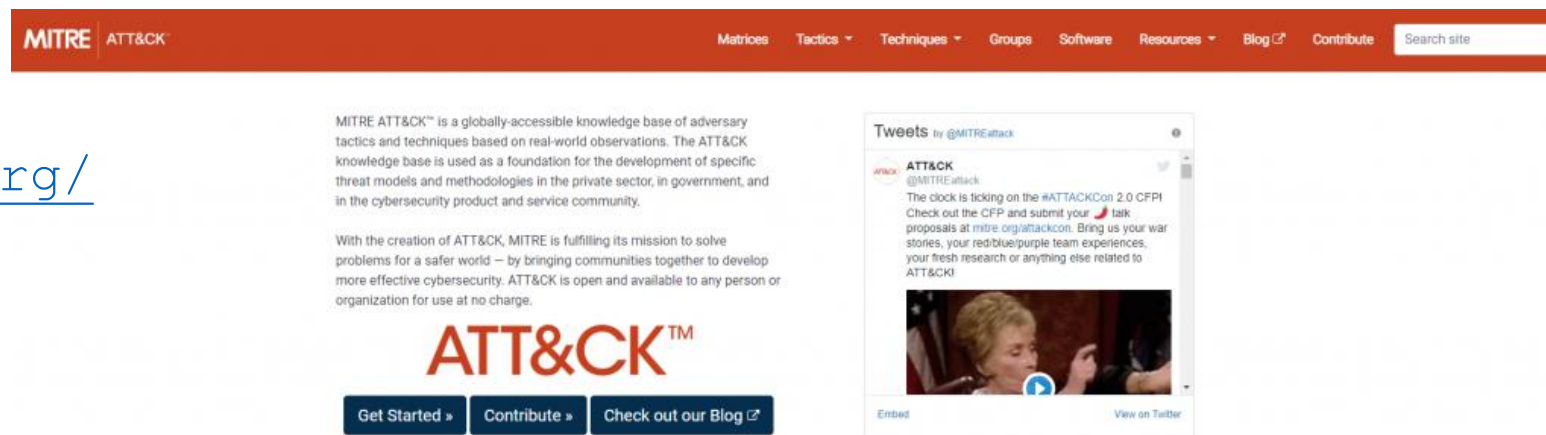
6. **Élévation de privilèges (TA0004)** – L'attaquant **obtient des droits administrateurs** pour contrôler l'environnement.
7. **Contournement des défenses (TA0005)** – L'attaquant évite la détection par l'EDR/AV en **désactivant les protections ou en utilisant des outils légitimes**.
8. **Accès aux identifiants (TA0006)** – L'attaquant vole des **mots de passe et tokens** pour faciliter sa progression.
9. **Découverte (TA0007)** – L'attaquant explore l'environnement pour trouver **de nouveaux accès, serveurs et fichiers sensibles**.
10. **Mouvement latéral (TA0008)** – L'attaquant **se propage** dans le réseau en compromettant d'autres machines.

Qu'est-ce que MITRE ATT&CK et quelle est son utilité?

Les tactiques

1. **Collecte (TA0009)** – L'attaquant **récupère** des fichiers sensibles, emails, bases de données.
2. **Exfiltration (TA0010)** – L'attaquant **exfiltre les données** en les envoyant vers un serveur externe.
3. **Command and Control (TA0011)** – L'attaquant garde le **contrôle à distance** via un serveur C2 (ex. : HTTP, DNS tunneling, services Cloud).
4. **Impact (TA0040)** – L'attaquant perturbe les systèmes en **lançant un ransomware, en supprimant des données ou en coupant des services**.

Qu'est-ce que MITRE ATT&CK et quelle est son utilité?

<https://attack.mitre.org/>

The screenshot shows the MITRE ATT&CK website. At the top is a navigation bar with links: Matrices, Tactics, Techniques, Groups, Software, Resources, Blog, and Contribute. Below this is a main content area with a description of MITRE ATT&CK as a globally-accessible knowledge base. It includes a tweet from @MITREattack about the #ATTACKcon 2.0 CFP. At the bottom of the main content area are three buttons: 'Get Started', 'Contribute', and 'Check out our Blog'.

ATT&CK Matrix for Enterprise

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Drive-by Compromise	AppleScript	bash_profile and .bashrc	Access Token Manipulation	Access Token Manipulation	Account Manipulation	Account Discovery	AppleScript	Audio Capture	Commonly Used Port	Automated Exfiltration	Data Destruction
Exploit Public-Facing Application	CMSTP	Accessibility Features	Accessibility Features	BITS Jobs	Bash History	Application Window Discovery	Application Deployment Software	Automated Collection	Communication Through Removable Media	Data Compressed	Data Encrypted for Impact
External Remote Services	Command-Line Interface	Account Manipulation	AppCert DLLs	Binary Padding	Brute Force	Browser Bookmark Discovery	Distributed Component Object Model	Clipboard Data	Connection Proxy	Data Encrypted	Defacement
Hardware Additions	Compiled HTML File	AppCert DLLs	AppCert DLLs	Bypass User Account Control	Credential Dumping	Domain Trust Discovery	Exploitation of Remote Services	Data Staged	Custom Command and Control Protocol	Data Transfer Size Limits	Disk Content Wipe
Replication Through Removable Media	Control Panel Items	AppCert DLLs	Application Shimming	CMSTP	Credentials in Files	File and Directory Discovery	Login Scripts	Data from Information Repositories	Custom Cryptographic Protocol	Exfiltration Over Alternative Protocol	Disk Structure Wipe
Speargrifting Attachment	Dynamic Data Exchange	Application Shimming	Bypass User Account Control	Clear Command History	Credentials in Registry	Network Service Scanning	Pass the Hash	Data from Local System	Data Encoding	Exfiltration Over Command and Control Channel	Endpoint Denial of Service
Unauthorized Local Admin	Execution Network API	Authentication Services	DLL Search Order	Porta Services	Exploitation for	Network Drive Permission	Share the Trust	Data from Network	Data Exfiltration	Exfiltration Over Other Network	Firmware

170

Qu'est-ce que MITRE ATT&CK et quelle est son utilité?

Enterprise Matrix

Below are the tactics and techniques representing the MITRE ATT&CK® Matrix for Enterprise. The Matrix contains information for the following platforms: Windows, macOS, Linux, PRE, Azure AD, Office 365, Google Workspace, SaaS, IaaS, Network, Containers.

[View on the ATT&CK® Navigator](#)[Version Permalink](#)

layout: side ▾ show sub-techniques hide sub-techniques help

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
10 techniques	8 techniques	9 techniques	14 techniques	19 techniques	13 techniques	42 techniques	17 techniques	31 techniques	9 techniques	17 techniques	16 techniques	9 techniques	13 techniques
Active Scanning (3)	Acquire Access	Drive-by Compromise	Cloud Administration Command	Account Manipulation (5)	Abuse Elevation Control Mechanism (4)	Abuse Elevation Control Mechanism (4)	Adversary-in-the-Middle (3)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (3)	Application Layer Protocol (4)	Automated Exfiltration (1)	Account Access Removal
Gather Victim Host Information (4)	Acquire Infrastructure (3)	Exploit Public-Facing Application	Command and Scripting Interpreter (9)	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
Gather Victim Identity Information (3)	Compromise Accounts (3)	External Remote Services	Container Administration Command	Boot or Logon Autostart Execution (14)	Boot or Logon Autostart Execution (14)	BITS Jobs	Credentials from Password Stores (3)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Data Encoding (2)	Exfiltration Over Alternative Protocol (3)	Data Encrypted for Impact
Gather Victim Network Information (6)	Compromise Infrastructure (7)	Hardware Additions	Deploy Container	Boot or Logon Initialization Scripts (5)	Boot or Logon Initialization Scripts (5)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)	Automated Collection	Data Obfuscation (3)	Exfiltration Over C2 Channel	Data Manipulation (3)
Gather Victim Org Information (4)	Develop Capabilities (4)	Phishing (3)	Exploitation for Client Execution	Browser Extensions	Create or Modify System Process (4)	Debugger Evasion	Forced Authentication	Cloud Service Dashboard	Remote Services (7)	Replication Through Removable Media	Dynamic Resolution (3)	Exfiltration Over Other Network Medium (1)	Defacement (2)
Phishing for information (3)	Establish Accounts (3)	Replication Through Removable Media	Inter-Process Communication (3)	Compromise Client Software Binary	Domain Policy Modification (2)	Deobfuscate/Decode Files or Information	Forge Web Credentials (2)	Cloud Storage Object Discovery	Clipboard Data	Software Deployment Tools	Encrypted Channel (2)	Exfiltration Over Physical Medium (1)	Disk Wipe (2)
Search Closed Sources (2)	Obtain Capabilities (6)	Supply Chain Compromise (3)	Native API	Create Account (3)	Escape to Host	Deploy Container	Input Capture (4)	Container and Resource Discovery	Taint Shared Content	Data from Cloud Storage	Fallback Channels	Exfiltration Over Web Service (3)	Endpoint Denial of Service (4)
Search Open Technical Databases (3)	Stage Capabilities (4)	Trusted Relationship	Scheduled Task/Job (5)	Create or Modify System Process (4)	Event Triggered Execution (14)	Direct Volume Access	Modify Authentication Process (8)	Debugger Evasion	Use Alternate Authentication Material (4)	Data from Configuration Repository (2)	Ingress Tool Transfer	Network Denial of Service (2)	Firmware Corruption
Search Open Websites/Domains (3)		Valid Accounts (4)	Serverless Execution	Event Triggered Execution (14)	Exploitation for Defense Evasion	Domain Policy Modification (2)	Multi-Factor Authentication Interception	Device Driver Discovery		Data from Information Repositories (3)	Multi-Stage Channels	Scheduled Transfer	Inhibit System Recovery
Search Victim-Owned Websites			Shared Modules	External Remote Services	Exploitation for Privilege Escalation	Execution Guardrails (1)	Multi-Factor Authentication Request Generation	File and Directory Permissions Modification (2)		Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	Resource Hijacking
			Software Deployment Tools	Hijack Execution Flow (12)	Hijack Execution Flow (12)	File and Directory Permissions Modification (2)	Network Sniffing	Hide Artifacts (10)		Data from Network Shared Drive	Non-Standard Port		Service Stop
			System Services (2)	Implant Internal Image	Process Injection (12)	Hijack Execution Flow (12)	Network Share Discovery	OS Credential Dumping (8)		Data from Removable Media	Proxy (4)		System Shutdown/Reboot
			User Execution (3)	Modify Authentication Process (8)	Scheduled Task/Job (5)	Impair Defenses (10)	Network Sniffing	OS Credential Dumping (8)		Data Staged (2)	Remote Access Software		
			Windows Management Instrumentation	Office Application Startup (8)	Valid Accounts (4)	Indicator Removal (9)	Password Policy Discovery	Steal Application Access Token		Email Collection (3)	Traffic Signaling (2)		
				Pre-OS Boot (3)		Indirect Command Execution	Peripheral Device Discovery	Steal or Forge Authentication Certificates		Input Capture (4)	Web Service (3)		
				Scheduled Task/Job (5)		Masquerading (8)	Permission Groups Discovery (3)	Steal or Forge Kerberos Tickets (4)		Screen Capture			
				Server Software Component (5)		Modify Authentication Process (8)	Process Discovery	Steal Web Session Cookie		Video Capture			
				Traffic Signaling (2)		Modify Cloud Compute Infrastructure (4)	Query Registry						
				Valid Accounts (4)		Modify Registry	Remote System Discovery						
						Modify System Image (2)	Software Discovery (1)						
						Network Boundary Bridging (1)	System Information Discovery						
						Obfuscated Files or Information (11)	System Location Discovery (1)						
						Plist File Modification	System Network Configuration Discovery (1)						
						Pre-OS Boot (5)	System Network Connections Discovery						
						Process Injection (12)	System Owner/User Discovery						
						Reflective Code Loading	System Service Discovery						

171

Qu'est-ce que MITRE ATT&CK et quelle est son utilité?

Mobile Matrix

Below are the tactics and techniques representing the two MITRE ATT&CK® Matrices for Mobile. The Matrices cover techniques involving device access and network-based effects that can be used by adversaries without device access. The Matrix contains information for the following platforms: Android, iOS.

[View on the ATT&CK® Navigator](#)

[Version Permalink](#)

layout: side ▾ show sub-techniques hide sub-techniques help

Initial Access 4 techniques	Execution 3 techniques	Persistence 7 techniques	Privilege Escalation 3 techniques	Defense Evasion 14 techniques	Credential Access 5 techniques	Discovery 8 techniques	Lateral Movement 2 techniques	Collection 13 techniques	Command and Control 8 techniques	Exfiltration 2 techniques	Impact 9 techniques
Drive-By Compromise	Command and Scripting Interpreter (1)	Boot or Logon Initialization Scripts	Abuse Elevation Control Mechanism (1)	Download New Code at Runtime	Access Notifications	File and Directory Discovery	Exploitation of Remote Services	Access Notifications	Application Layer Protocol (1)	Exfiltration Over Alternative Protocol (1)	Account Access Removal
Lockscreen Bypass	Native API	Compromise Application Executable	Exploitation for Privilege Escalation	Execution Guardrails (1)	Clipboard Data	Location Tracking (2)	Replication Through Removable Media	Adversary-in-the-Middle	Call Control	Exfiltration Over C2 Channel	Call Control
Replication Through Removable Media	Scheduled Task/Job	Compromise Client Software Binary	Process Injection (1)	Foreground Persistence	Credentials from Password Store (1)	Network Service Scanning		Archive Collected Data	Dynamic Resolution (1)		Data Encrypted for Impact
Supply Chain Compromise (3)		Event Triggered Execution (1)		Hide Artifacts (2)	Input Capture (2)	Process Discovery		Audio Capture	Encrypted Channel (2)		Data Manipulation (1)
		Foreground Persistence		Hooking	Steal Application Access Token (1)	Software Discovery (1)		Call Control	Ingress Tool Transfer		Endpoint Denial of Service
		Hijack Execution Flow (1)		Impair Defenses (3)		System Information Discovery		Clipboard Data	Non-Standard Port		Generate Traffic from Victim
		Scheduled Task/Job		Indicator Removal on Host (3)		System Network Configuration Discovery		Data from Local System	Out of Band Data		Input Injection
				Input Injection		System Network Connections Discovery		Input Capture (2)	Web Service (3)		Network Denial of Service
				Native API				Location Tracking (2)			SMS Control
				Obfuscated Files or Information (2)				Protected User Data (4)			
				Process Injection (1)				Screen Capture			
				Proxy Through Victim				Stored Application Data			
				Subvert Trust Controls (1)				Video Capture			
				Virtualization/Sandbox Evasion (1)							

172

Qu'est-ce que MITRE ATT&CK et quelle est son utilité?

ICS Matrix

Below are the tactics and techniques representing the MITRE ATT&CK® Matrix for ICS.

[View on the ATT&CK® Navigator ↗](#)

[Version Permalink](#)

Initial Access 12 techniques	Execution 9 techniques	Persistence 6 techniques	Privilege Escalation 2 techniques	Evasion 6 techniques	Discovery 5 techniques	Lateral Movement 7 techniques	Collection 11 techniques	Command and Control 3 techniques	Inhibit Response Function 14 techniques	Impair Process Control 5 techniques	Impact 12 techniques
Drive-by Compromise	Change Operating Mode	Hardcoded Credentials	Exploitation for Privilege Escalation	Change Operating Mode	Network Connection Enumeration	Default Credentials	Adversary-in-the-Middle	Commonly Used Port	Activate Firmware Update Mode	Brute Force I/O	Damage to Property
Exploit Public-Facing Application	Command-Line Interface	Modify Program	Hooking	Exploitation for Evasion	Network Sniffing	Exploitation of Remote Services	Automated Collection	Connection Proxy	Alarm Suppression	Modify Parameter	Denial of Control
Exploitation of Remote Services	Execution through API	Module Firmware		Indicator Removal on Host	Remote System Discovery	Hardcoded Credentials	Data from Information Repositories	Standard Application Layer Protocol	Block Command Message	Module Firmware	Denial of View
External Remote Services	Graphical User Interface	Project File Infection		Masquerading	Remote System Information Discovery	Lateral Tool Transfer	Data from Local System		Block Reporting Message	Spoof Reporting Message	Loss of Availability
Internet Accessible Device	Hooking	System Firmware		Rootkit	Wireless Sniffing	Program Download	Detect Operating Mode		Block Serial COM	Unauthorized Command Message	Loss of Control
Remote Services	Modify Controller Tasking	Valid Accounts		Spoof Reporting Message		Remote Services	I/O Image		Change Credential		Loss of Productivity and Revenue
Replication Through Removable Media	Native API					Valid Accounts	Monitor Process State		Data Destruction		Loss of Protection
Rogue Master	Scripting						Point & Tag Identification		Denial of Service		Loss of Safety
Spearphishing Attachment	User Execution						Program Upload		Device Restart/Shutdown		Loss of View
Supply Chain Compromise							Screen Capture		Manipulate I/O Image		Manipulation of Control
Transient Cyber Asset							Wireless Sniffing		Modify Alarm Settings		Manipulation of View
Wireless Compromise									Rootkit		Theft of Operational Information
									Service Stop		
									System Firmware		

173

Qu'est-ce que MITRE ATT&CK et quelle est son utilité?

1. Que pouvez vous me dire sur le malware « **Cobian RAT** » ?
2. Lancer le **navigateur de la matrice** permettant de sélectionner les techniques pour décrire les différentes phases de l'attaque

<https://attack.mitre.org/software/>

MITRE ATT&CK®		Matrices	Tactics ▾	Techniques ▾	Data Sources	Mitigations ▾	Groups	Software	Resources ▾	Blog ↗	Contribute	Search 🔍
SOFTWARE		S0338	Cobian RAT					Cobian RAT is a backdoor, remote access tool that has been observed since 2016.				
Overview		S0369	CoinTicker					CoinTicker is a malicious application that poses as a cryptocurrency price ticker and installs components of the open source backdoors EvilOSX and EggShell.				
3PARA RAT												
4H RAT												

MITRE ATT&CK® Navigator

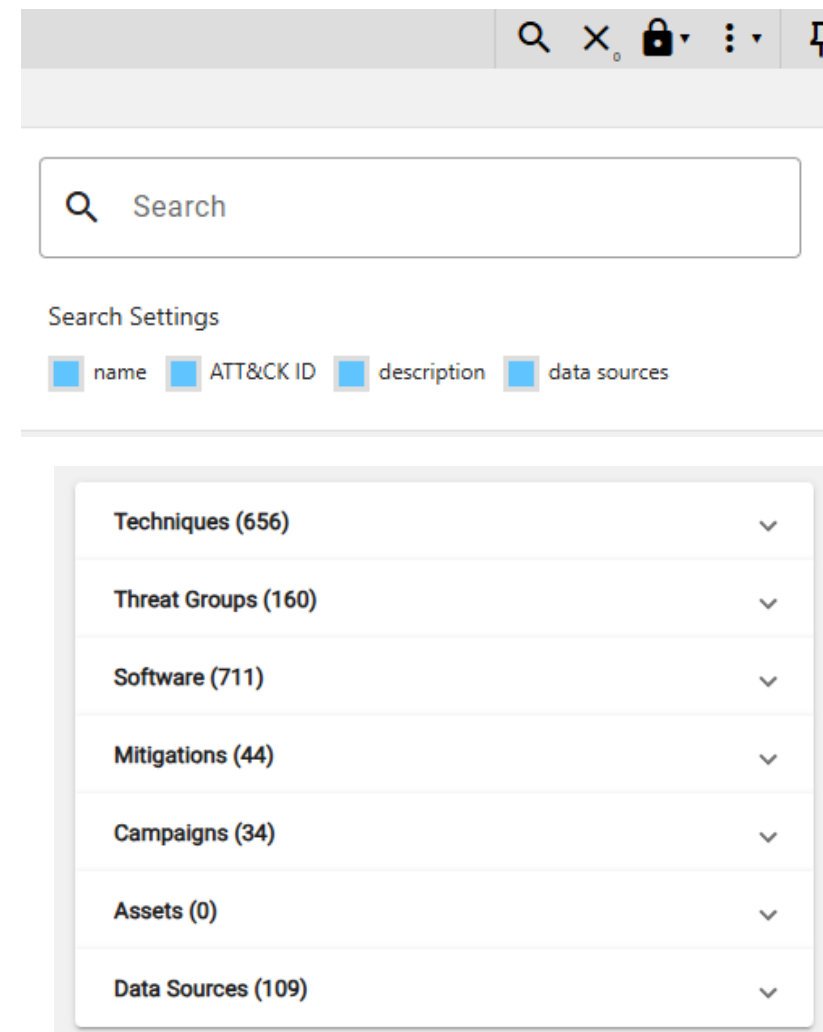
MITRE ATT&CK® Navigator

The ATT&CK Navigator is a web-based tool for annotating and exploring ATT&CK matrices. It can be used to visualize defensive coverage, red/blue team planning, the frequency of detected techniques, and more.

[help](#) [changelog](#) [theme ▾](#)

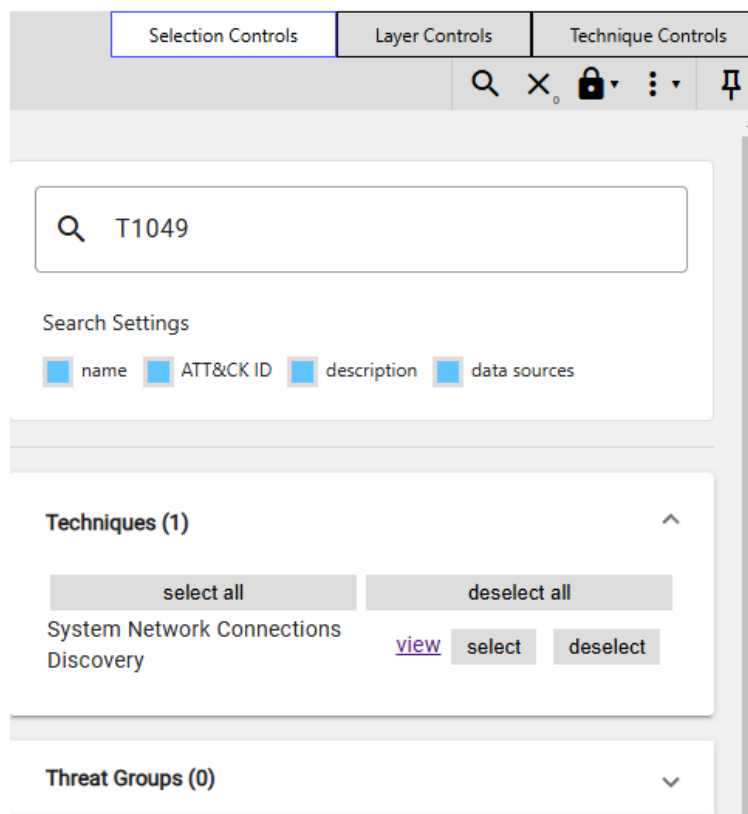
Create New Layer	Create a new empty layer
Open Existing Layer	Load a layer from your computer or a URL
Create Layer from Other Layers	Select layers to inherit properties from
Create Customized Navigator	Create a hyperlink to a customized ATT&CK Navigator

<https://mitre-attack.github.io/attack-navigator/>



175

MITRE ATT&CK® Navigator

<https://mitre-attack.github.io/attack-navigator/>


The screenshot shows the MITRE ATT&CK Navigator interface. At the top, there are tabs for 'Selection Controls', 'Layer Controls', and 'Technique Controls'. Below these is a search bar containing 'T1049'. Under the search bar, there are 'Search Settings' with checkboxes for 'name', 'ATT&CK ID', 'description', and 'data sources'. Below the settings, there is a section titled 'Techniques (1)' with a list of techniques. At the bottom, there are buttons for 'select all', 'deselect all', 'view', 'select', and 'deselect'. The interface also shows 'System Network Connections Discovery' and 'Threat Groups (0)'.

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
10 techniques	8 techniques	10 techniques	14 techniques	20 techniques	14 techniques	44 techniques	17 techniques	32 techniques	9 techniques	17 techniques	18 techniques	9 techniques	14 techniques
Active Scanning (0/3) Gather Victim Host Information (0/4) Gather Victim Identity Information (0/3) Gather Victim Network Information (0/6) Gather Victim Org Information (0/4) Phishing for Information (0/4) Search Closed Sources (0/2) Search Open Technical Databases (0/3) Search Open Websites/Domains (0/3) Search Victim-Owned Websites	Acquire Access (0/3) Acquire Infrastructure (0/3) Compromise Accounts (0/2) Compromise Infrastructure (0/6) Develop Capabilities (0/4) Establish Accounts (0/3) Obtain Capabilities (0/7) Stage Capabilities (0/6) Supply Chain Compromise (0/3) Trusted Relationship (0/4) Valid Accounts (0/4)	Content Injection (0/3) Drive-by Compromise (0/1) Exploit Public-Facing Application (0/1) External Remote Services (0/4) Hardware Additions (0/4) Phishing (0/4) Replication Through Removable Media (0/3) Stage Capabilities (0/6) Supply Chain Compromise (0/3) Trusted Relationship (0/4) Valid Accounts (0/4)	Cloud Administration Command (0/3) Command and Scripting Interpreter (0/11) Container Administration Command (0/3) Deploy Container (0/3) Exploitation for Client Execution (0/3) Inter-Process Communication (0/3) Native API (0/3) Scheduled Task/Job (0/5) Serverless Execution (0/5) Shared Modules (0/3) Software Deployment Tools (0/2) System Services (0/2) User Execution (0/3) Windows Management Instrumentation (0/6) Office Application Startup (0/6) Power Settings (0/5)	Account Manipulation (0/7) BITS Jobs (0/5) Boot or Logon Autostart Execution (0/14) Boot or Logon Initialization Scripts (0/5) Browser Extensions (0/14) Compromise Host Software Binary (0/3) Create Account (0/3) Create or Modify System Process (0/5) Domain or Tenant Policy Modification (0/5) Event Triggered Execution (0/17) External Remote Services (0/13) Hijack Execution Flow (0/13) Implant Internal Image (0/13) Modify Authentication Process (0/9) Office Application Startup (0/6) Power Settings (0/5)	Abuse Elevation Control Mechanism (0/6) Access Token Manipulation (0/5) Account Manipulation (0/7) Boot or Logon Autostart Execution (0/14) Boot or Logon Initialization Scripts (0/5) Create or Modify System Process (0/5) Domain or Tenant Policy Modification (0/5) Event Triggered Execution (0/17) External Remote Services (0/13) Hijack Execution Flow (0/13) Implant Internal Image (0/13) Modify Authentication Process (0/9) Office Application Startup (0/6) Power Settings (0/5)	Abuse Elevation Control Mechanism (0/6) Access Token Manipulation (0/5) BITS Jobs (0/5) Build Image on Host (0/6) Debugger Evasion (0/7) Deobfuscate/Decode Files or Information (0/14) Deploy Container (0/3) Direct Volume Access (0/3) Domain or Tenant Policy Modification (0/2) Execution Guardrails (0/2) Exploitation for Defense Evasion (0/2) File and Directory Permissions Modification (0/2) Hide Artifacts (0/12) Hijack Execution Flow (0/13) Impair Defenses (0/11) Impersonation (0/10) Indicator Removal (0/10) Process Injection (0/12) Scheduled Task/Job (0/5) Masquerading (0/10)	Adversary-in-the-Middle (0/4) Brute Force (0/4) Credentials from Password Stores (0/6) Exploitation for Credential Access (0/7) Forged Authentication (0/2) Forge Web Credentials (0/2) Input Capture (0/4) Modify Authentication Process (0/9) Multi-Factor Authentication Interception (0/9) Multi-Factor Authentication Request Generation (0/9) Network Sniffing (0/13) OS Credential Dumping (0/8) Steal Application Access Token (0/2) Steal or Forge Authentication Certificates (0/3) Steal or Forge Authentication Certificates (0/3)	Account Discovery (0/4) Application Window Discovery (0/3) Browser Information Discovery (0/3) Cloud Infrastructure Discovery (0/2) Cloud Service Dashboard (0/2) Cloud Service Discovery (0/6) Cloud Storage Object Discovery (0/2) Container and Resource Discovery (0/2) Debugger Evasion (0/7) Device Driver Discovery (0/2) Domain Trust Discovery (0/2) File and Directory Discovery (0/2) Group Policy Discovery (0/2) Log Enumeration (0/2) Network Service Discovery (0/2) Network Share Discovery (0/2) Network Sniffing (0/2) Password Policy Discovery (0/2) Peripheral Device Discovery (0/2) Web Service (0/3)	Exploitation of Remote Services (0/4) Internal Spearphishing (0/3) Lateral Tool Transfer (0/3) Remote Service Session Hijacking (0/2) Remote Services (0/6) Replication Through Removable Media (0/2) Software Deployment Tools (0/2) Taint Shared Content (0/4) Use Alternate Authentication Material (0/4)	Adversary-in-the-Middle (0/4) Archive Collected Data (0/3) Audio Capture (0/3) Automated Collection (0/3) Browser Session Hijacking (0/3) Clipboard Data (0/3) Data from Cloud Storage (0/2) Data from Configuration Repository (0/2) Data from Information Repositories (0/5) Data from Local System (0/2) Data from Network Shared Drive (0/2) Data from Removable Media (0/2) Data Staged (0/2) Email Collection (0/3) Input Capture (0/4)	Application Layer Protocol (0/5) Communication Through Removable Media (0/3) Content Injection (0/2) Data Encoding (0/2) Data Obfuscation (0/3) Dynamic Resolution (0/2) Encrypted Channel (0/2) Fallback Channels (0/2) Hide Infrastructure (0/2) Ingress Tool Transfer (0/2) Multi-Stage Channels (0/4) Non-Application Layer Protocol (0/2) Non-Standard Port (0/2) Protocol Tunneling (0/4) Proxy (0/4) Remote Access Software (0/2) Traffic Signaling (0/2) Web Service (0/3)	Automated Exfiltration (0/1) Data Transfer Size Limits (0/1) Exfiltration Over Alternative Protocol (0/3) Exfiltration Over C2 Channel (0/2) Exfiltration Over Other Network Medium (0/1) Fallback Channels (0/2) Hide Infrastructure (0/2) Ingress Tool Transfer (0/2) Multi-Stage Channels (0/4) Non-Application Layer Protocol (0/2) Non-Standard Port (0/2) Protocol Tunneling (0/4) Proxy (0/4) Remote Access Software (0/2) Traffic Signaling (0/2) Web Service (0/3)	Account Access Removal (0/1) Data Destruction (0/1) Data Encrypted for Impact (0/1) Data Manipulation (0/2) Defacement (0/2) Disk Wipe (0/2) Endpoint Denial of Service (0/4) Financial Theft (0/2) Firmware Corruption (0/2) Inhibit System Recovery (0/2) Network Denial of Service (0/2) Resource Hijacking (0/4) Service Stop (0/2) System Shutdown/Reboot (0/2)


<https://www.youtube.com/watch?v=7RyHnYyZSsw>

FORENSIC

Expertises légales en informatique



176

Windows Sandbox

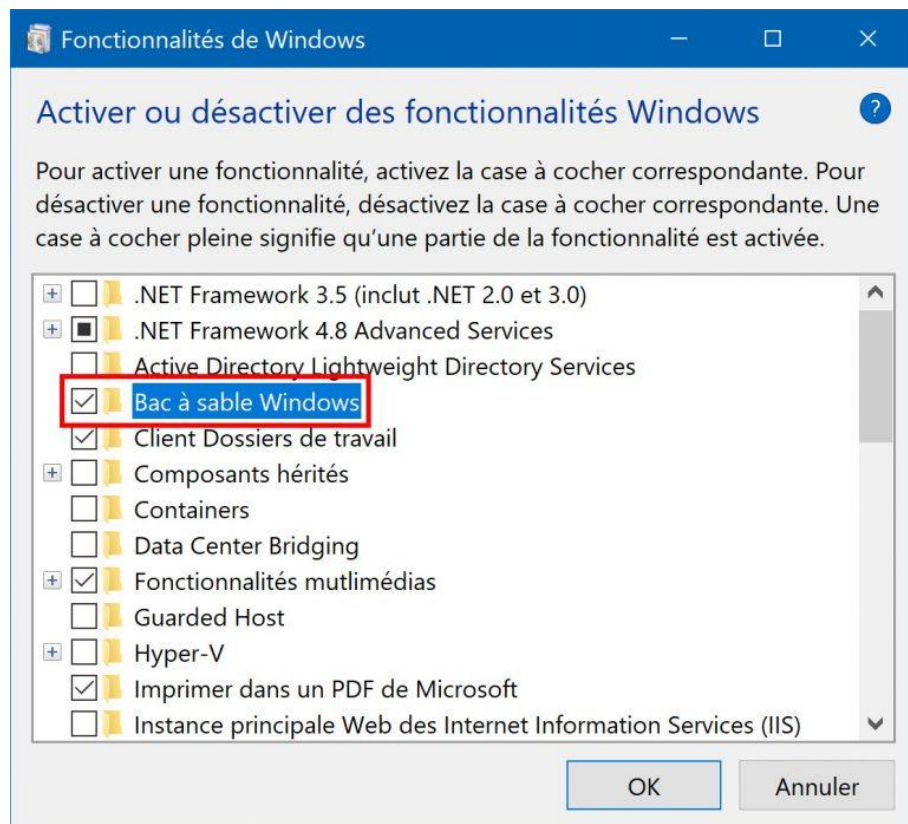


Windows Sandbox est une application « bac à sable » qui permet de créer un environnement sécurisé et isolé du reste du système afin de pouvoir y exécuter des programmes et des fichiers en toute sécurité. Windows Sandbox est inclus nativement dans Windows 10 Professionnel et Windows 10 Entreprise depuis la [version 1909 \(19H1\)](#).

Avec Windows Sandbox, vous pouvez tester un programme potentiellement dangereux ou vérifier si un fichier est fiable ou non sans mettre en danger votre installation principale de Windows 10.

Windows Sandbox

Win+R → optionalfeatures



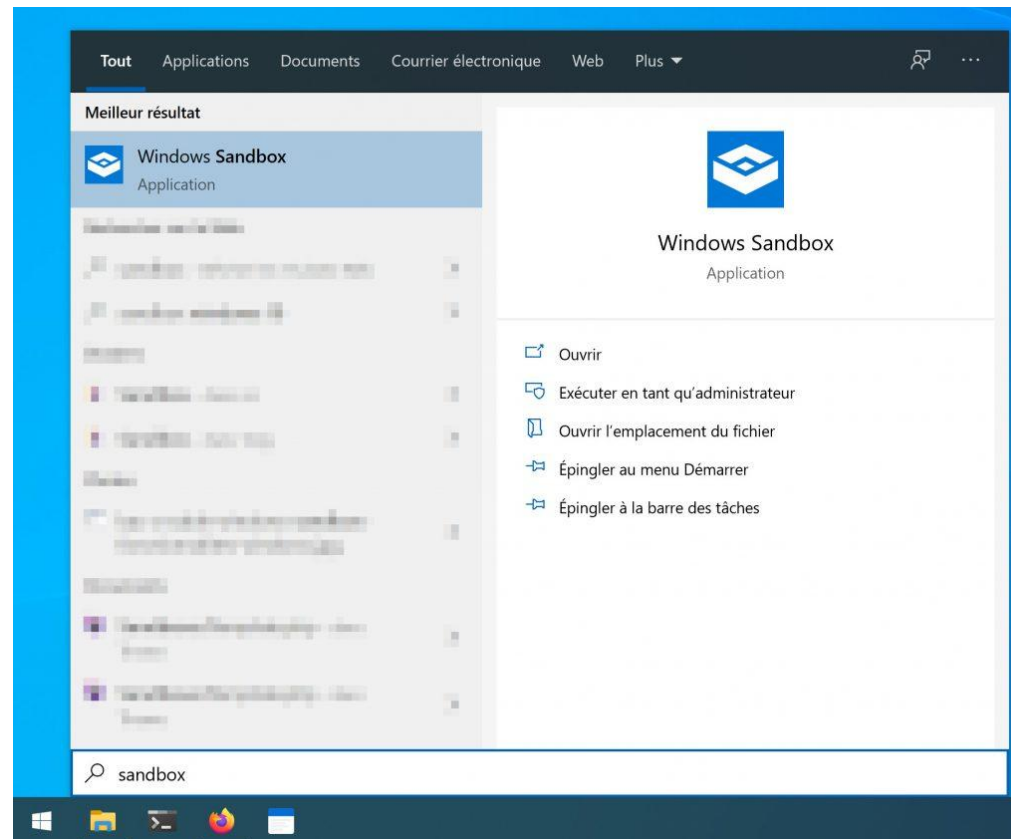
Pour activer le bac à sable Windows sur votre PC, cela nécessite quelques prérequis :

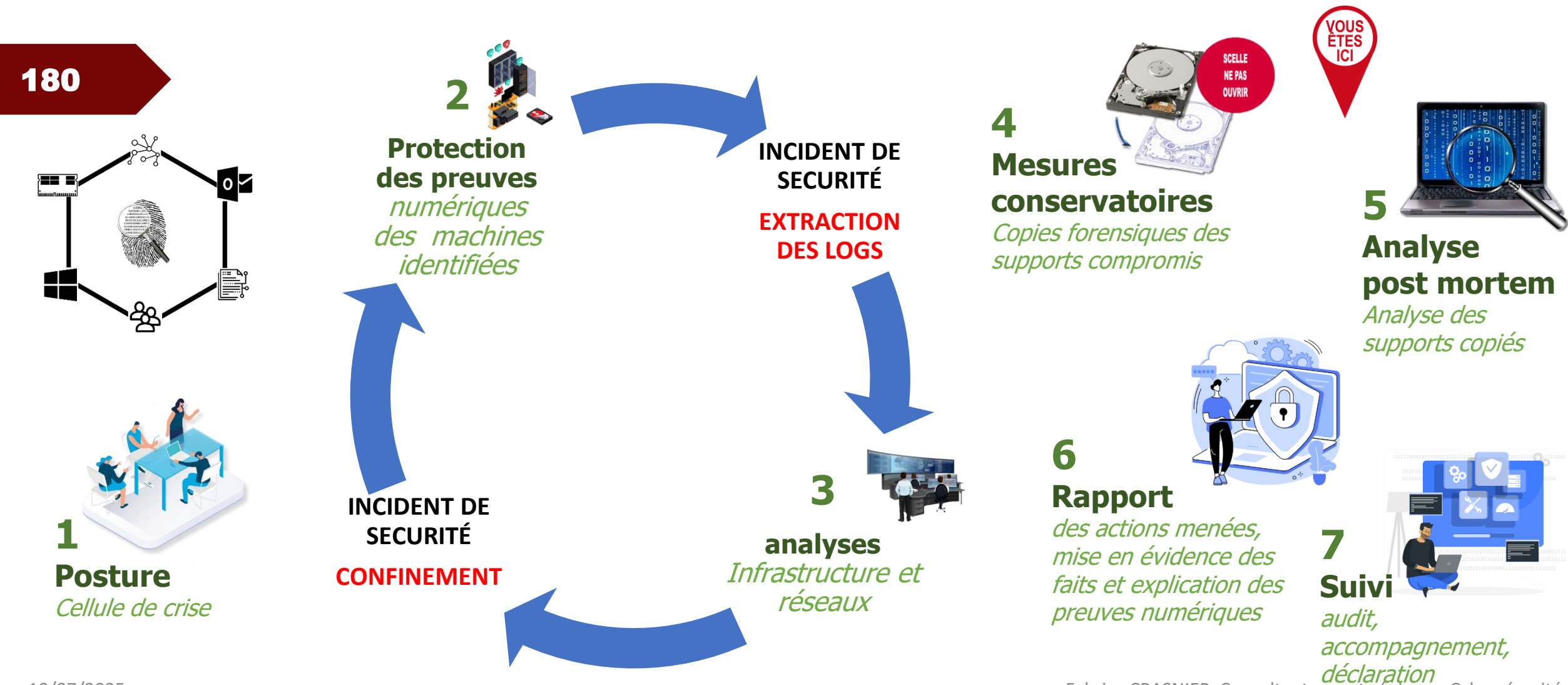
- **Windows 11/10 Professionnel ou Enterprise**
(Windows Sandbox n'est actuellement pas pris en charge sur Windows 11/10 Famille)
- **Architecture AMD64**
- Fonctionnalité de virtualisation activée dans le BIOS/UEFI
- Au moins 4 Go de RAM (8 Go recommandés)
- Au moins 1 Go d'espace disque disponible (SSD recommandé)
- Un processeur (CPU) doté d'au moins deux cœurs (quatre cœurs avec l'hyperthreading recommandé)

179

Windows Sandbox

Win+S → Sandbox





FORENSIC

Expertises légales en informatique

L'expertise en informatique légale (*forensic*) est une investigation numérique légale qui a pour objet la **collecte de preuves numériques** afin de fournir la capacité à une personne de **soutenir une action en justice** ou de **faire reconnaître un droit**.

182

Bonnes pratiques de la collecte de données



Parmi les bonnes pratiques à mettre en place, **une politique des mesures conservatoires** paraît indispensable à qui doit justifier de la genèse d'un incident de sécurité sur le système d'information et de ses impacts sur l'entreprise.



N'oublions pas que ces éléments sont destinés à permettre une **action en justice** et à **justifier du niveau de maturité** de votre système d'information au regard de certaines **exigences ou obligations légales**.





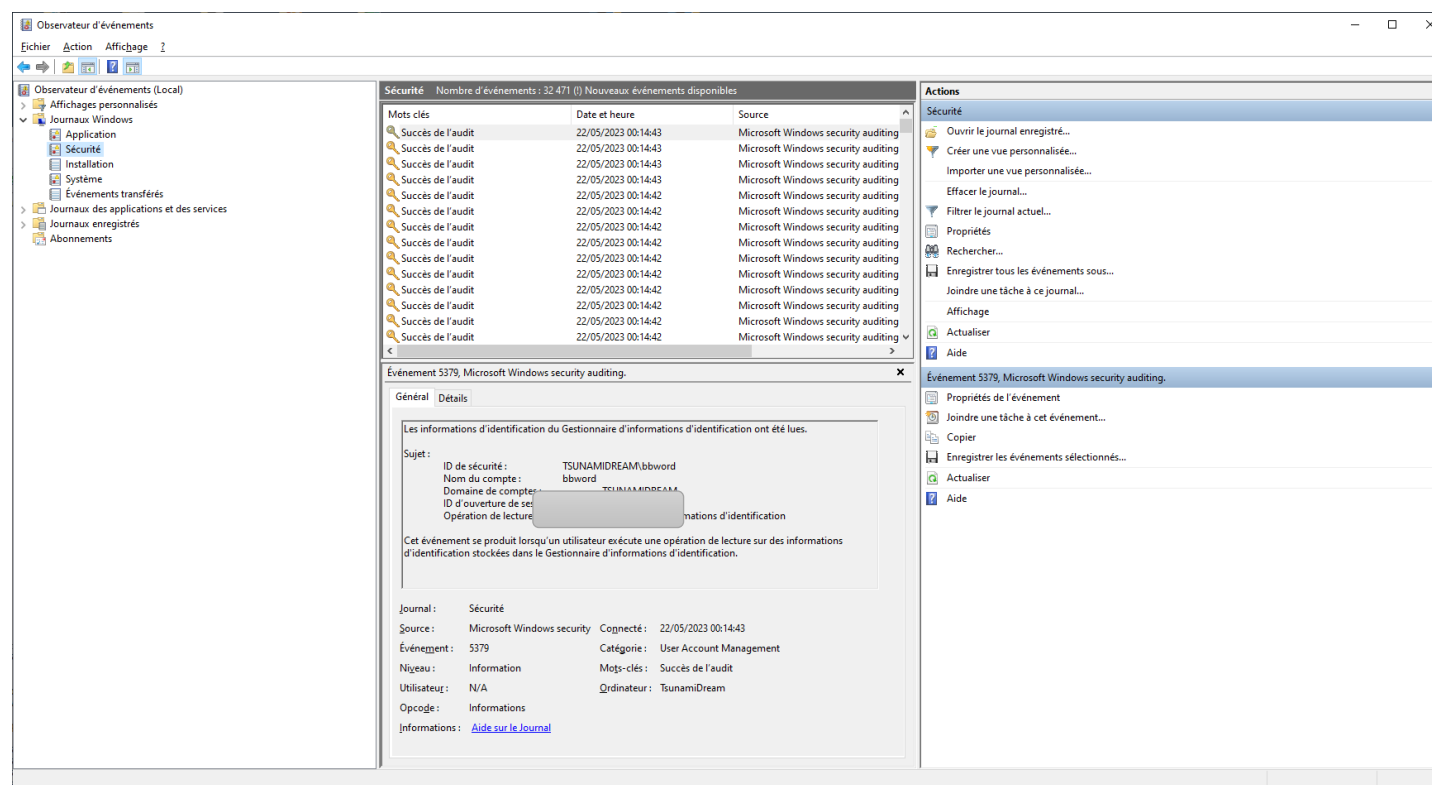
Logs windows



L'observateur d'événements (en anglais, *events viewer*) est un composant du système d'exploitation Microsoft. Il permet aux utilisateurs et aux administrateurs de voir le journal des événements d'un ordinateur sur cet ordinateur ou sur une machine distante.

Sélectionner :

- le menu Démarrer
- Panneau de configuration
- Outils d'administration
- Observateur d'événements

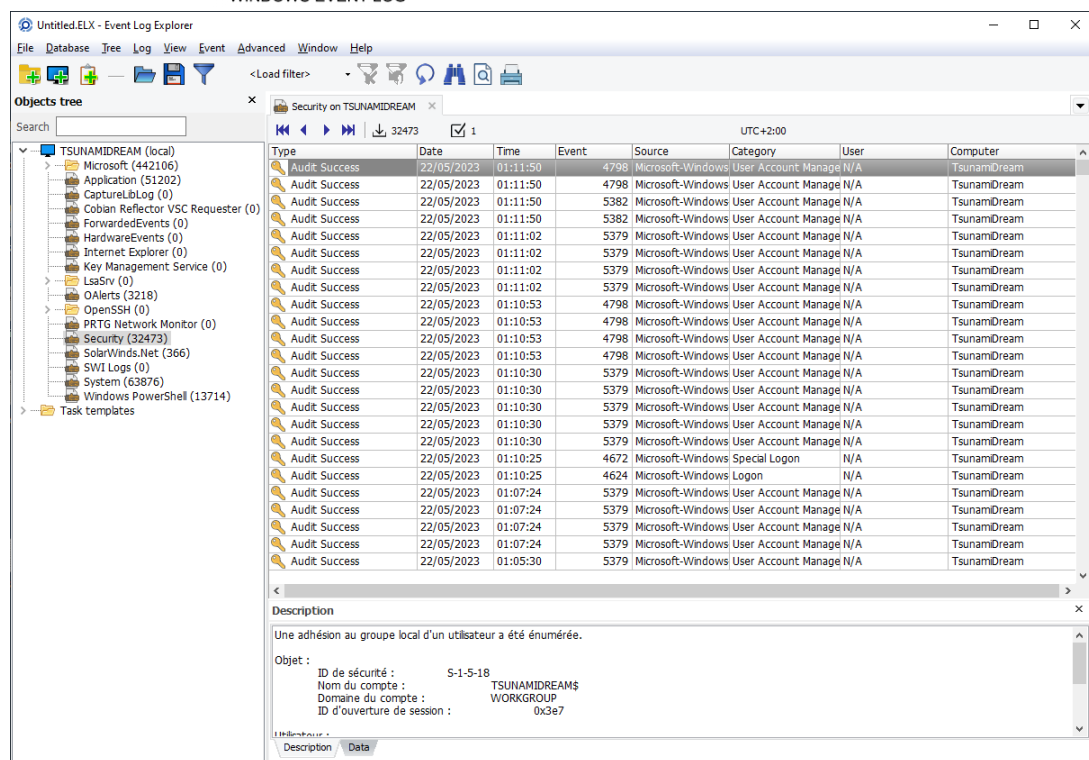


184

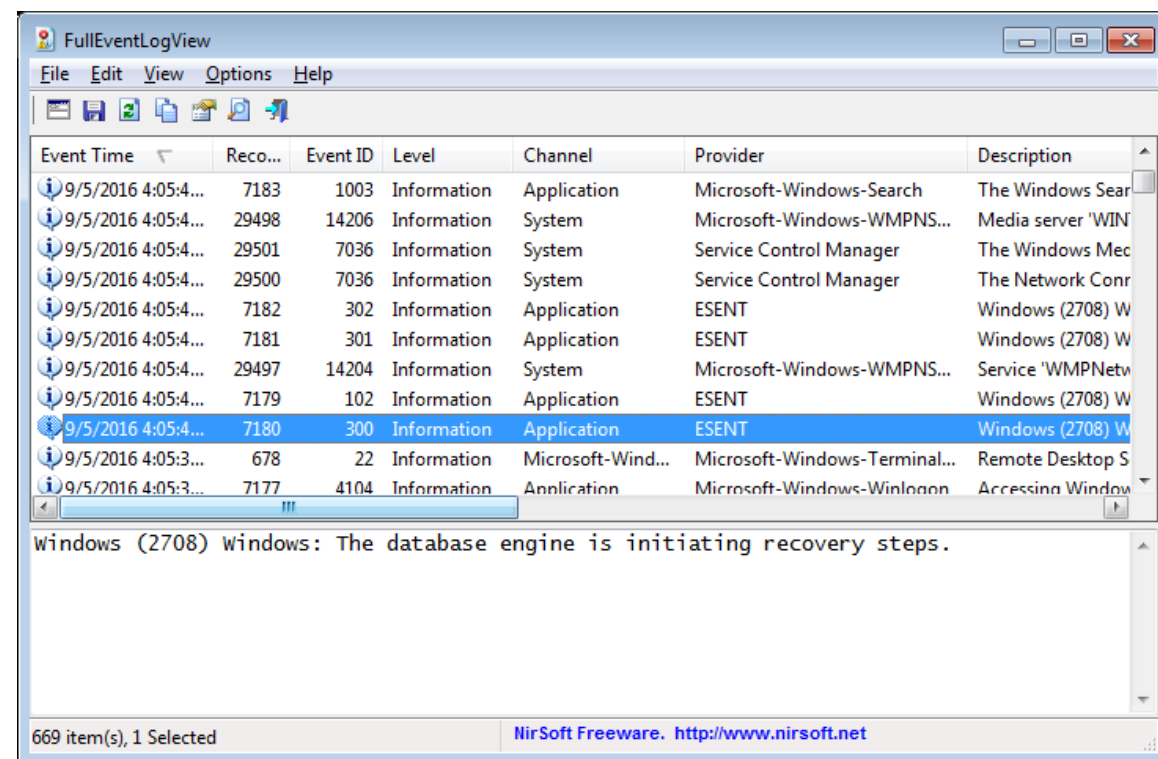


WINDOWS EVENT LOG

Logs windows

<https://eventlogxp.com/>

FullEventLogView v1.77

https://www.nirsoft.net/utis/full_event_log_view.html

FORENSIC

Expertises légales en informatique

Un Laboratoire d'analyse dispose des outils les plus performants et les plus récents du marché.

Sa mission : la recherche de preuves numériques et remédiation de collecte de preuves numérique sur un SI.

Le matériel est qualifié par l'expertise légale.

Dans le cadre de **mesures conservatoires** sont utilisés des outils garantissant l'intégrité de la preuve numérique

Dans le cadre de **l'analyse Forensic**, nous disposons des outils garantissant la continuité de l'intégrité et la capacité de réaliser en profondeur des investigations sur l'ensemble des supports numériques.

outils



**T35u -
Bloqueur
SATA/IDE
avec USB 3.0**



**TABLEAU TX1
copie
forensique**



**Nouvelle plateforme UFED
Touch 2**



PALADIN Forensic Toolbox
A Powerful Linux Distribution Built for Forensics. For Free.



**INTERNET
EVIDENCE
FINDER™**



X-Ways
X-Ways Forensic



Autopsy®
OPEN | EXTENSIBLE | FAST



**Blocage en
écriture USB
avec le TK8u**

Constitution d'un dossier de plainte + dépôt de plainte

- ☐ Informer le juriste le conseil de l'entreprise
- ☐ Identification d'un expert en investigation numérique légale (Forensic), si besoin
- ☐ Mettre en relation l'expert et le juriste pour la mise en place d'une stratégie de poursuite
- ☐ Procédure d'analyse des données explicatives de la compromission
- ☐ Identification du service à contacter (police / prestataire)
- ☐ Identification du représentant légal pour déposer une plainte
- ☐ Procédure simple (plainte par internet)



Encadrement du vol de données à caractère personnel

- ❑ **Informez le/la DPO** et le/la juriste de l'entreprise
- ❑ **Sauvegarde des registres des activités de traitement** (*Le registre tenu par le responsable du traitement doit recenser l'ensemble des traitements mis en œuvre par votre organisme et si besoin le registre du sous-traitant pour les traitements que vous opérez, en tant que sous-traitant, pour le compte de vos clients.*)
- ❑ **Prévenir sur l'état du sinistre dans les 72 heures suivant de la constatation de la violation (RGPD)** (*L'obligation de notifier à la CNIL les violations de données à caractère personnel est prévue à l'article 33 du règlement général sur la protection des données.*)



188

Merci de votre attention

A votre disposition pour un approfondissement

Maître de conférences associé

Doctorant en intelligence artificielle

*Ecole doctorale MITT Mathématiques Informatique
Télécommunications de Toulouse.*

Laboratoire IRIT - Equipe SMAC

Systèmes Multi-Agents Coopératifs

Avenue de l'étudiant, 31400 Toulouse

Courriel : fabrice.crasnier@irit.fr



UNIVERSITÉ
TOULOUSE III
PAUL SABATIER



Faculté
Sciences
et Ingénierie

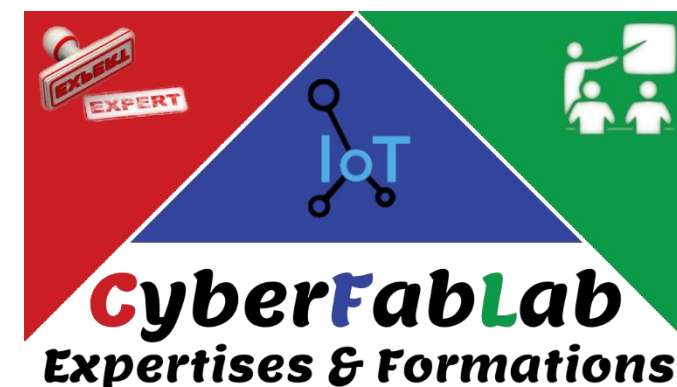
Domaines de compétences

- ☐ Formations en cybersécurité
- ☐ Réponse sur incident de sécurité
- ☐ Gestion de crise, conseil juridique
- ☐ Construction d'un dossier de plainte
- ☐ Expertises pénales et civiles



Ecole Doctorale Mathématiques, Informatique
et Télécommunications de Toulouse

Expert en Cybersécurité



Tel : 06.24.49.39.20

Courriel : fabrice.crasnier@cyberfablab.fr